BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC GIA ĐỊNH

KHOA: CÔNG NGHỆ THÔNG TIN

TIỂU LUẬN

THIẾT KẾ VÀ TRIỂN KHAI HỆ THỐNG TƯỜNG LỬA THẾ HỆ MỚI CHO DOANH NGHIỆP

MÔN: CÔNG NGHỆ TƯỜNG LỬA

Ngành: **CÔNG NGHỆ THÔNG TIN**

Chuyên ngành (*nếu có*): **AN TOÀN THÔNG TIN**

Giảng viên hướng dẫn: **ThS.TRANG NHẬT QUANG**

Sinh viên thực hiện: **LÊ ĐỨC QUYỀN**

MSSV: **23150247**

Lớp học phần: **231501 - 020100116202**

TP. Hồ Chí Minh, tháng 8 năm 2025

MỤC LỤC

MỤC LỤC 1
LỜI CẢM ƠN 3
LỜI CAM ĐOAN 4
DANH MỤC VIẾT TẮT 5
CHƯƠNG I: TỔNG QUAN VỀ CÔNG NGHỆ TƯỜNG LỬA 6
1.1. Đặt vấn đề 6
1.2. Khái niệm về tường lửa (Firewall) 6
1.3. Mục tiêu và chức năng chính của tường lửa 6
1.3.1 Kiểm soát truy cập (Access Control) 6
1.3.2 Bảo vệ trước các tấn công mạng 6
1.3.3 Ghi nhật ký và giám sát (Logging and Monitoring) 6
1.3.4 Tạo kênh kết nối an toàn (VPN) 6
1.3.5 Quản lý ứng dụng và nội dung 6
1.4. cách hoạt động của tường lửa 7
1.5. Mục đích của tường lửa trong bảo mật mạng 7
1.6. Các loại tường lửa phổ biến 8
1.7. Tường lửa thế hệ mới (Next Generation Firewall - NGFW) 10
1.8. Ưu điểm, nhược điểm của từng loại 11
1.8.1.Ưu điểm và nhược điểm của các loại tường lửa thế hệ cũ 11
1.8.2. Ưu điểm và nhược điểm của tường lửa thế hệ mới (Next-Generation Firewall – NGFW) 12
1.9. Một số nhà cung cấp tường lửa NGFW hàng đầu hiện nay 13
1.10. Vai trò của tường lửa trong hệ thống mạng doanh nghiệp 13
1.11. Xu hướng phát triển công nghệ tường lửa 14
1.12. Kết luận chương 15
CHƯƠNG II: THIẾT KẾ KIẾN TRÚC HỆ THỐNG TƯỜNG LỬA CHO DOANH NGHIỆP 16
2.1. Phân tích môi trường và yêu cầu bảo mật 16

2.1.1. Mô hình doanh nghiệp 16
2.1.2. Yêu cầu bảo mật 16
2.2. Yêu cầu thiết kế hệ thống tường lửa 16
2.2.1. Mục tiêu thiết kế 16
2.2.2. Yêu cầu kỹ thuật 17
2.3. Thiết kế phân vùng bảo mật (Security Zones) 17
2.4. Kiến trúc triển khai thực tế 18
2.4.1. Tổng quan sơ đồ hệ thống 18
2.4.2. Phân tích chức năng từng vùng 19
2.5. Cấu trúc VLAN và phân mạng 19
2.6. Lựa chọn giải pháp tường lửa NGFW 20
2.6.1. Giải pháp sử dụng 20
2.6.2. Lý do lựa chọn 20
Chương 3: TRIỂN KHAI VÀ CẤU HÌNH HỆ THỐNG TƯỜNG LỬA 21
3.1.Cấu hình Routing, NAT 21
3.1.1.Cấu hình Zone: 21
3.1.2.Cấu hình Interface và DHCP: 21
3.1.3.Cấu hình NAT Policy: 22
3.1.4.Cấu hình Secutiry Policy: 22
3.2.IPS Policy 23
3.3.SSL Policy 25
3.4.File and Malware Policy 25
3.5.URL Filtering 27
3.6.Application Control 29
3.7.Cấu hình remote access cho người làm việc từ xa 30
3.8.VPN site to site: 33
Chương 4:KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN 43
4.1. Kết luận 43
4.2. Hướng phát triển 43
TÀI LIỆU THAM KHẢO 46

LỜI CẢM ƠN

Tôi xin gửi lời cảm ơn chân thành và sâu sắc nhất đến giảng viên Trang Nhật Quang, người đã tận tình hướng dẫn, định hướng khoa học và cung cấp những gợi ý quý giá trong suốt quá trình thực hiện tiểu luận. Sự hỗ trợ tận tâm cùng những góp ý mang tính xây dựng của thầy đã giúp tôi vượt qua những thách thức kỹ thuật và hoàn thiện quy trình nghiên cứu một cách tốt nhất.

Bên cạnh đó, tôi xin bày tỏ lòng tri ân đến Trường Đại Học Gia Định và các thầy cô trong Khoa Công Nghệ Thông Tin, những người đã tạo điều kiện thuận lợi, cung cấp môi trường học tập chuyên nghiệp, cơ sở vật chất hiện đại cùng nguồn tài liệu phong phú như sách, báo, giúp tôi có nền tảng vững chắc để thực hiện nghiên cứu. Tôi cũng xin cảm ơn các công trình nghiên cứu, tài liệu tham khảo và các nguồn thông tin đáng tin cậy đã cung cấp kiến thức nền tảng để tôi phát triển đề tài.

Cuối cùng, tôi hy vọng rằng tiểu luận này sẽ mang lại giá trị khoa học và thực tiễn, đóng góp một phần nhỏ vào lĩnh vực công nghệ tường lửa và mở ra những hướng nghiên cứu mới trong tương lai.

Trân trọng!

LỜI CAM ĐOAN

Chúng em xin cam đoan bài tiểu luận với đề tài "Thiết kế và triển khai hệ thống tường lửa thế hệ mới cho đoanh nghiệp" là công trình nghiên cứu độc lập do nhóm chúng em thực hiện dưới sự hướng dẫn của giảng viên Trang Nhật Quang.

Tất cả nội dung trình bày trong tiểu luận, bao gồm: sơ đồ mạng, các bước triển khai hệ thống tường lửa, cấu hình thiết bị, đánh giá kết quả, cũng như các phương pháp kỹ thuật được sử dụng đều được nhóm thực hiện một cách trung thực, minh bạch và tuân thủ nghiêm túc các nguyên tắc đạo đức học thuật.

Chúng em cam kết không sao chép, không sử dụng nội dung từ bất kỳ tài liệu hay công trình nào khác mà không trích dẫn rõ ràng nguồn tham khảo. Nhóm chúng em hoàn toàn chịu trách nhiệm về tính chính xác, trung thực và tính nguyên bản của toàn bộ nội dung tiểu luận này.

Nếu có bất kỳ hành vi vi phạm đạo đức học thuật nào bị phát hiện, chúng em xin chịu hoàn toàn trách nhiệm và chấp nhận mọi hình thức xử lý theo quy định của nhà trường và pháp luật hiện hành.

DANH MỤC VIẾT TẮT

Viết tắt	Ý nghĩa tiếng Anh	Diễn giải tiếng Việt
FW	Firewall	Tường lửa
LAN	Local Area Network	Mạng cục bộ
WAN	Wide Area Network	Mạng diện rộng
DPI	Deep Packet Inspection	Phân tích sâu gói tin
IPS	Intrusion Prevention System	Hệ thống ngăn chặn xâm nhập
IDS	Intrusion Detection System	Hệ thống phát hiện xâm nhập
VPN	Virtual Private Network	Mạng riêng ảo
NGFW	Next Generation Firewall	Tường lửa thế hệ mới
UTM	Unified Threat Management	Quản lý mối đe dọa hợp nhất
AMP	Advanced Malware Protection	Bảo vệ chống mã độc nâng cao
SSL/TLS	Secure Sockets Layer / Transport Layer Security	Giao thức bảo mật truyền thông
ACL	Access Control List	Danh sách kiểm soát truy cập

CHƯƠNG I: TỔNG QUAN VỀ CÔNG NGHỆ TƯỜNG LỬA

1.1. Đặt vấn đề

Trong bối cảnh công nghệ thông tin phát triển nhanh chóng, việc kết nối Internet là điều kiện bắt buộc đối với các doanh nghiệp hiện đại. Tuy nhiên, điều này cũng khiến doanh nghiệp đối mặt với nhiều rủi ro an ninh mạng như xâm nhập trái phép, tấn công từ chối dịch vụ (DoS/DDoS), phần mềm độc hại, và rò rỉ dữ liệu nhạy cảm.

Tường lửa (Firewall) là một trong những giải pháp quan trọng và phổ biến nhất để đảm bảo an ninh mạng cho hệ thống thông tin. Công nghệ tường lửa đã không ngừng phát triển qua các thế hệ, từ dạng lọc gói đơn giản đến các tường lửa thế hệ mới tích hợp nhiều chức năng bảo mật nâng cao.

1.2. Khái niệm về tường lửa (Firewall)

Tường lửa là một hệ thống bảo mật được thiết kế để kiểm soát lưu lượng dữ liệu vào và ra khỏi một mạng dựa trên một tập hợp các quy tắc an ninh đã được định nghĩa trước. Tường lửa có thể là phần mềm, phần cứng hoặc kết hợp cả hai, và thường được đặt tại ranh giới giữa mạng nội bộ (LAN) và Internet để giám sát lưu lượng, phát hiện và ngăn chặn truy cập trái phép.

1.3. Mục tiêu và chức năng chính của tường lửa

1.3.1 Kiểm soát truy cập (Access Control)

Cho phép hoặc từ chối các kết nối mạng dựa trên các tiêu chí như địa chỉ IP nguồn/đích, cổng giao tiếp, giao thức, thời gian truy cập,...

1.3.2 Bảo vệ trước các tấn công mạng

Ngăn chặn truy cập trái phép vào hệ thống nội bộ.

Phát hiện các hành vi bất thường như quét cổng, khai thác lỗ hổng, và tấn công brute-force.

Lọc các gói tin chứa mã độc hoặc có dấu hiệu tấn công.

1.3.3 Ghi nhật ký và giám sát (Logging and Monitoring)

Tường lửa ghi lại toàn bộ các sự kiện và lưu lượng ra vào hệ thống để phục vụ việc giám sát, phân tích, và truy vết sự cố bảo mật.

1.3.4 Tạo kênh kết nối an toàn (VPN)

Cung cấp kết nối an toàn giữa trụ sở chính, chi nhánh và người dùng làm việc từ xa thông qua các công nghệ VPN.

1.3.5 Quản lý ứng dụng và nội dung

Kiểm soát quyền truy cập các ứng dụng mạng, trang web, và dịch vụ không phù hợp với chính sách công ty.

1.4. cách hoạt động của tường lửa

Ghi nhận và kiểm tra gói tin: Tường lửa thực hiện việc giám sát tất cả các gói dữ liệu đi qua, đồng thời phân tích chúng dựa trên nhiều tiêu chí như địa chỉ IP nguồn và đích, số hiệu cổng (port), giao thức truyền thông và nội dung gói tin nếu cần.

Xác định quyết định: Dựa trên các chính sách bảo mật và cấu hình do quản trị viên thiết lập, tường lửa sẽ quyết định xem một gói tin nên được cho phép, từ chối hoặc chuyển hướng đến một cơ chế xử lý đặc biệt (như IDS/IPS).

Lọc các cuộc tấn công: Tường lửa có khả năng phát hiện và ngăn chặn các hình thức tấn công phổ biến như DDoS, SYN Flood, port scanning, hoặc các cuộc tấn công lợi dụng lỗ hổng mạng khác.

Kiểm soát truy cập: Tường lửa đóng vai trò quan trọng trong việc kiểm soát quyền truy cập của người dùng và thiết bị đối với hệ thống mạng nội bộ, thông qua việc thiết lập các quy tắc cụ thể dựa trên danh tính, vai trò hoặc địa chỉ IP.

Ghi log và báo cáo: Mọi hoạt động đáng chú ý đều được tường lửa ghi lại trong các file log. Những dữ liệu này hỗ trợ quá trình phân tích bảo mật, đánh giá hiệu suất mạng, và phục vụ cho công tác điều tra sự cố khi cần thiết.

1.5. Mục đích của tường lửa trong bảo mật mạng

Tường lửa được triển khai nhằm đạt các mục tiêu chính sau:

Ngăn chặn truy cập trái phép:

Bảo vệ hệ thống mạng nội bộ khỏi các truy cập không được phép từ bên ngoài, đặc biệt là từ Internet.

Kiểm soát lưu lượng mạng:

Cho phép hoặc từ chối các gói dữ liệu đi vào hoặc ra khỏi mạng dựa trên các quy tắc được cấu hình trước.

Phòng chống tấn công mạng:

Hạn chế và ngăn chặn các cuộc tấn công phổ biến như: tấn công từ chối dịch vụ (DoS), quét cổng, tấn công brute-force, khai thác lỗ hổng,...

Bảo vệ dữ liệu nhạy cảm:

Giữ cho thông tin trong mạng nội bộ được an toàn, tránh rò rỉ dữ liệu ra ngoài.

Ghi nhật ký và giám sát an ninh:

Lưu lại các hoạt động đáng ngờ để phục vụ công tác giám sát, phân tích và điều tra sau này.

1.6. Các loại tường lửa phổ biến

Các loại tường lửa có thể được chia thành nhiều loại khác nhau dựa trên cấu trúc chung và phương thức hoạt động của chúng.

Tường lửa lọc gói tin (Packet-filtering firewalls)

Là kiểu kiến trúc tường lửa "cơ bản" nhất và lâu đời nhất, tường lửa lọc gói về cơ bản tạo một trạm kiểm soát tại bộ định tuyến hoặc bộ chuyển mạch lưu lượng. Tường lửa thực hiện kiểm tra đơn giản các gói dữ liệu đi qua bộ định tuyến — kiểm tra thông tin như địa chỉ IP đích và nguồn gốc, loại gói, số cổng và thông tin cấp bề mặt khác mà không cần mở gói để kiểm tra nội dung của nó.

Nếu gói thông tin không vượt qua kiểm tra, nó sẽ bị loại bỏ.

Điều tốt về những bức tường lửa này là chúng không tốn nhiều tài nguyên. Điều này có nghĩa là chúng không có tác động lớn đến hiệu suất hệ thống và tương đối đơn giản. Tuy nhiên, chúng cũng tương đối dễ vượt qua so với tường lửa có khả năng kiểm tra mạnh mẽ hơn.

Cổng cấp mạch (Circuit-level gateways)

Là một loại tường lửa đơn giản khác có nghĩa là nhanh chóng và dễ dàng phê duyệt hoặc từ chối lưu lượng truy cập mà không tiêu tốn tài nguyên máy tính đáng kể, các cổng cấp mạch hoạt động bằng cách xác minh giao thức điều khiển TCP. Kiểm tra TCP này được thiết kế để đảm bảo rằng gói dữ liệu truyền đến là hợp pháp.

Mặc dù cực kỳ tiết kiệm tài nguyên nhưng các bức tường lửa này không tự kiểm tra gói tin. Vì vậy, nếu một gói chứa phần mềm độc hại, nhưng có sự bắt tay TCP phù hợp, thì nó sẽ đi qua ngay. Đây là lý do tại sao các cổng cấp mạch không đủ để tự bảo vệ doanh nghiệp của bạn.

Tường lửa kiểm tra trạng thái (Stateful inspection firewalls)

Tường lửa kiểm tra trạng thái cho phép hoặc chặn lưu lượng truy cập dựa trên các đặc tính kỹ thuật, chẳng hạn như giao thức gói, địa chỉ IP hoặc cổng cụ thể. Tuy nhiên, các tường lửa này cũng theo dõi và lọc duy nhất dựa trên trạng thái của các kết nối bằng cách sử dụng bảng trạng thái.

Tường lửa proxy (proxy firewalls)

Proxy Firewall, còn được gọi là tường lửa cấp ứng dụng (lớp 7), là duy nhất trong việc đọc và lọc các giao thức ứng dụng. Những hoạt động này kết hợp giữa kiểm tra mức ứng dụng hoặc "kiểm tra gói sâu (DPI)" và kiểm tra trạng thái.

Tường lửa proxy càng gần với hàng rào vật lý thực tế càng tốt. Không giống như các loại tường lửa khác, nó hoạt động như một hai máy chủ bổ sung giữa các mạng bên ngoài và máy tính chủ nội bộ, với một máy chủ làm đại diện (hoặc "proxy") cho mỗi mạng.

Lọc dựa trên dữ liệu cấp ứng dụng thay vì chỉ địa chỉ IP, cổng và giao thức gói cơ bản (UDP, ICMP) như trong tường lửa dựa trên gói. Đọc và hiểu FTP, HTTP, DNS và các lệnh khác cho phép điều tra sâu hơn và lọc chéo cho nhiều đặc điểm dữ liệu khác nhau.

Nếu có một nhược điểm đối với tường lửa proxy, đó là chúng có thể tạo ra sự chậm lại đáng kể do các bước bổ sung trong quá trình truyền gói dữ liệu.

Tường lửa thế hệ tiếp theo (Next-gen firewalls)

Tường lửa thế hệ tiếp theo dành riêng cho mối đe dọa được thiết kế để kiểm tra và xác định các mối nguy hiểm cụ thể, chẳng hạn như phần mềm độc hại nâng cao , ở cấp độ chi tiết hơn. Được sử dụng thường xuyên hơn bởi các doanh nghiệp và các mạng phức tạp, chúng cung cấp một giải pháp toàn diện để lọc ra các mối nguy hiểm.

Tường lửa phần mềm (Software firewalls)

Tường lửa phần mềm bao gồm bất kỳ loại tường lửa nào được cài đặt trên thiết bị cục bộ chứ không phải là một phần cứng riêng biệt (hoặc máy chủ đám mây). Lợi ích của tường lửa phần mềm là nó rất hữu ích trong việc tạo khả năng phòng thủ theo chiều sâu bằng cách cô lập các điểm cuối mạng riêng lẻ với nhau.

Tường lửa phần cứng (Hardware firewalls)

Tường lửa phần cứng sử dụng một thiết bị vật lý hoạt động theo cách tương tự như bộ định tuyến lưu lượng để chặn các gói dữ liệu và yêu cầu lưu lượng trước khi chúng được kết nối với máy chủ của mạng. Tường lửa dựa trên thiết bị vật lý vượt trội về bảo mật ngoại vi bằng cách đảm bảo chặn lưu lượng độc hại từ bên ngoài mạng trước khi các điểm cuối mạng của công ty gặp rủi ro.

Tường lửa đám mây (Cloud firewalls)

Bất cứ khi nào giải pháp đám mây được sử dụng để cung cấp tường lửa, nó có thể được gọi là tường lửa đám mây hoặc tường lửa dưới dạng dịch vụ (FaaS). Tường lửa đám mây được nhiều người coi là đồng nghĩa với tường lửa proxy, vì máy chủ đám mây thường được sử dụng trong thiết lập tường lửa proxy.

Lợi ích lớn của việc có tường lửa đám mây là chúng rất dễ mở rộng quy mô với tổ chức của bạn. Khi nhu cầu của bạn tăng lên, bạn có thể thêm dung lượng bổ sung cho máy chủ đám mây để lọc tải lưu lượng lớn hơn. Tường lửa đám mây, giống như tường lửa phần cứng, vượt trội về bảo mật chu vi.

1.7. Tường lửa thế hệ mới (Next Generation Firewall - NGFW)

Tường lửa thế hệ mới là sự kết hợp giữa khả năng kiểm soát truy cập truyền thống và các chức năng bảo mật nâng cao để đối phó với các mối đe dọa hiện đại. NGFW cung cấp cái nhìn sâu và toàn diện hơn về lưu lượng mạng, hành vi ứng dụng, và người dùng.

Các tính năng nổi bật của NGFW:

- DPI (Deep Packet Inspection): Phân tích nội dung thực sự của gói tin.

- IPS (Intrusion Prevention System): Phát hiện và ngăn chặn tấn công trong thời gian thực.

- Application Control: Xác định và giới hạn quyền truy cập vào các ứng dụng cụ thể như Facebook, YouTube, Dropbox,...

- URL Filtering: Cho phép/chặn truy cập website theo danh mục hoặc danh sách đen/trắng.

- SSL/TLS Inspection: Giải mã và phân tích lưu lượng mã hóa để phát hiện mã độc.

- Malware Detection & Sandboxing: Phân tích hành vi tệp tin trong môi trường cách ly.

So sánh giữa tường lửa thế hệ cũ và tường lửa thế hệ mới:

Tiêu chí	**Tường lửa thế hệ cũ (Traditional Firewall)**	**Tường lửa thế hệ mới (NGFW)**
Nguyên lý hoạt động	Dựa trên kiểm tra địa chỉ IP, cổng (port) và giao thức (protocol)	Phân tích sâu đến lớp ứng dụng (Layer 7)
Lớp OSI xử lý chính	Lớp 3 (Network) và lớp 4 (Transport)	Lên tới lớp 7 (Application Layer)
Khả năng kiểm soát ứng dụng	Không hỗ trợ	Có thể nhận diện và kiểm soát theo ứng dụng cụ thể

Tích hợp hệ thống phát hiện xâm nhập (IDS/IPS)	Không có hoặc rất hạn chế	Tích hợp sẵn IDS/IPS giúp phát hiện và ngăn chặn tấn công
Xác thực người dùng	Không hoặc rất đơn giản (dựa trên IP)	Hỗ trợ xác thực theo người dùng/nhóm AD/LDAP
Kiểm soát nội dung	Không	Có thể lọc URL, nội dung web, virus, phần mềm độc hại
Khả năng phân tích lưu lượng mã hóa (SSL/TLS)	Không hoặc rất hạn chế	Có thể giải mã và phân tích lưu lượng SSL/TLS
Mức độ bảo mật	Trung bình, dễ bị tấn công hiện đại vượt qua	Cao, phù hợp với các mối đe dọa tinh vi hiện nay
Hiệu suất	Cao hơn (do chức năng đơn giản)	Có thể thấp hơn nếu bật nhiều tính năng nâng cao
Giá thành	Rẻ hơn	Đắt hơn, phù hợp với doanh nghiệp
Đối tượng sử dụng	Hộ gia đình, doanh nghiệp nhỏ	Doanh nghiệp vừa và lớn, tổ chức yêu cầu bảo mật cao

1.8. Ưu điểm, nhược điểm của từng loại

1.8.1.Ưu điểm và nhược điểm của các loại tường lửa thế hệ cũ

Tường lửa thế hệ cũ bao gồm các loại như Packet Filtering Firewall, Stateful Inspection Firewall, Circuit-level Gateway và Application Proxy Firewall. Đây là những giải pháp bảo mật được sử dụng phổ biến trong giai đoạn đầu phát triển của công nghệ mạng, với cơ chế hoạt động chủ yếu dựa trên địa chỉ IP, cổng và giao thức. Trong đó, Packet Filtering Firewall có ưu điểm là cấu hình đơn giản, dễ triển khai và tiêu tốn ít tài nguyên, phù hợp với các hệ thống mạng nhỏ. Tuy nhiên, nó không thể theo dõi trạng thái kết nối, không kiểm tra nội dung gói tin, và dễ bị tấn công bởi các kỹ thuật giả mạo như IP spoofing.

Stateful Inspection Firewall cải tiến hơn khi có thể theo dõi trạng thái của các phiên kết nối TCP, cung cấp mức độ bảo mật cao hơn Packet Filtering. Mặc dù vậy, nó vẫn không có khả năng kiểm tra dữ liệu ở lớp ứng dụng và khó phát hiện các mối đe dọa ẩn sâu bên trong lưu lượng mạng. Circuit-level Gateway lại tập trung vào việc kiểm soát phiên kết nối TCP, hỗ trợ tính năng ẩn danh người dùng và hoạt động hiệu quả với các giao thức như SOCKS proxy. Dù vậy, loại này không kiểm tra nội dung gói tin, và chỉ phù hợp với các hệ thống đơn giản, không yêu cầu kiểm soát chặt chẽ.

Application Proxy Firewall là một bước tiến khi có thể hoạt động ở lớp ứng dụng (Layer 7), cho phép kiểm tra nội dung chi tiết và cung cấp mức độ bảo mật cao hơn. Tuy nhiên, nhược điểm của loại tường lửa này là hiệu suất thấp khi xử lý lượng lớn lưu lượng, đồng thời việc triển khai và cấu hình cũng phức tạp hơn. Nhìn chung, các loại tường lửa thế hệ cũ mang lại lợi thế về chi phí và đơn giản trong triển khai, nhưng không còn phù hợp để bảo vệ hệ thống mạng hiện đại trước các mối đe dọa ngày càng tinh vi và đa dạng.

1.8.2. Ưu điểm và nhược điểm của tường lửa thế hệ mới (Next-Generation Firewall – NGFW)

Tường lửa thế hệ mới (NGFW) ra đời nhằm khắc phục các điểm yếu còn tồn tại ở các mô hình truyền thống. Khác với các tường lửa cũ chỉ kiểm tra lưu lượng ở mức IP và cổng, NGFW có khả năng phân tích sâu vào nội dung lưu lượng mạng, đặc biệt là tại lớp ứng dụng (Layer 7). Điều này giúp NGFW nhận diện và kiểm soát chính xác các ứng dụng cụ thể như Facebook, YouTube, Zalo, Skype… thay vì chỉ dựa vào địa chỉ hoặc cổng kết nối. Đây là một yếu tố then chốt giúp các tổ chức quản lý lưu lượng truy cập một cách linh hoạt và hiệu quả hơn.

Một điểm mạnh nổi bật khác là NGFW thường được tích hợp sẵn các tính năng bảo mật nâng cao như hệ thống phát hiện và ngăn chặn xâm nhập (IDS/IPS), lọc web, quét mã độc, kiểm tra tệp tin, giám sát lưu lượng mã hóa (SSL/TLS inspection) và xác thực người dùng thông qua Active Directory hoặc LDAP. Ngoài ra, nhiều NGFW hiện đại còn có khả năng kết nối với hệ thống giám sát an ninh tập trung như SIEM và nền tảng tự động hóa phản ứng sự cố (SOAR), giúp phản ứng nhanh chóng trước các mối nguy hại theo thời gian thực.

Tuy nhiên, NGFW không phải không có nhược điểm. Chi phí triển khai ban đầu và chi phí bản quyền phần mềm khá cao, đặc biệt đối với các doanh nghiệp vừa và nhỏ. Ngoài ra, NGFW yêu cầu phần cứng mạnh mẽ để vận hành ổn định, đặc biệt khi bật đồng thời nhiều tính năng. Việc quản trị và cấu hình NGFW cũng đòi hỏi đội ngũ kỹ thuật có trình độ chuyên môn cao. Nếu không tối ưu hợp lý, hiệu suất hệ thống có thể bị ảnh hưởng nghiêm trọng, dẫn đến suy giảm hiệu quả hoạt động.

Tổng kết lại, NGFW là giải pháp tường lửa toàn diện và mạnh mẽ, rất phù hợp với các tổ chức, doanh nghiệp hiện đại – nơi yêu cầu bảo mật không chỉ dừng lại ở việc ngăn chặn truy cập trái phép mà còn phải phát hiện và phản ứng kịp thời trước các mối đe dọa phức tạp. Dù chi phí đầu tư và độ phức tạp cao hơn, nhưng giá trị bảo vệ và khả năng thích ứng với môi trường mạng hiện đại mà NGFW mang lại là hoàn toàn xứng đáng.

1.9. Một số nhà cung cấp tường lửa NGFW hàng đầu hiện nay

Nhà cung cấp	Sản phẩm tiêu biểu	Đặc điểm nổi bật
Cisco	Cisco Firepower	Tích hợp quản lý tập trung, chống mã độc nâng cao (AMP), nhiều chính sách linh hoạt
Palo Alto	Palo Alto NGFW	Công nghệ App-ID và User-ID độc quyền, tự động hóa bảo mật
Fortinet	FortiGate	Giá thành hợp lý, hiệu năng cao, tích hợp UTM (quản lý mối đe dọa hợp nhất)
Check Point	Check Point NGFW	Quản lý tập trung mạnh mẽ, bảo mật sâu theo lớp ứng dụng

1.10. Vai trò của tường lửa trong hệ thống mạng doanh nghiệp

Trong hệ thống mạng của doanh nghiệp, tường lửa đóng vai trò như tuyến phòng thủ đầu tiên nhằm bảo vệ toàn bộ hạ tầng CNTT khỏi các mối đe dọa từ bên ngoài. Tường lửa giúp ngăn chặn các cuộc tấn công mạng, bảo vệ các dịch vụ nội bộ quan trọng như máy chủ web, máy chủ email, máy chủ lưu trữ dữ liệu và các hệ thống thông tin khác. Đồng thời, nó còn thực hiện chức năng giám sát và kiểm

tra toàn bộ lưu lượng mạng, giúp phát hiện các hành vi bất thường hoặc truy cập trái phép. Ngoài ra, tường lửa còn hỗ trợ doanh nghiệp trong việc quản lý truy cập người dùng, áp dụng các chính sách bảo mật phù hợp với từng nhóm hoặc vai trò, và tạo điều kiện cho việc kết nối từ xa một cách an toàn thông qua cơ chế xác thực và mã hóa.

Đặc biệt, trong bối cảnh môi trường làm việc hiện đại ngày càng phân tán về mặt địa lý – với nhiều chi nhánh, văn phòng đại diện hoặc người lao động làm việc từ xa – tường lửa thế hệ mới (NGFW) giữ vai trò trung tâm trong việc triển khai mạng riêng ảo (VPN). Nhờ đó, người dùng có thể truy cập vào dữ liệu và tài nguyên nội bộ của doanh nghiệp một cách an toàn, ở bất kỳ đâu và bất kỳ thời điểm nào. Sự linh hoạt và khả năng bảo mật mạnh mẽ của tường lửa NGFW chính là yếu tố then chốt giúp doanh nghiệp duy trì hoạt động ổn định, liên tục và an toàn trong thời đại số.

1.11. Xu hướng phát triển công nghệ tường lửa

Tích hợp Trí tuệ nhân tạo (AI) và học máy (Machine Learning)

Việc tích hợp trí tuệ nhân tạo (AI) và học máy (Machine Learning) vào tường lửa thế hệ mới (NGFW) trở thành một xu hướng tất yếu. AI cho phép tường lửa không chỉ dựa vào các chữ ký tấn công cố định mà còn phân tích hành vi mạng để phát hiện các dấu hiệu bất thường. Nhờ khả năng học hỏi liên tục từ dữ liệu mạng thực tế, hệ thống có thể nhận diện sớm các mối đe dọa chưa từng thấy (zero-day attack) và phản ứng nhanh chóng. Ngoài ra, AI giúp giảm số lượng cảnh báo giả, giúp đội ngũ an ninh mạng tập trung vào các sự kiện thực sự quan trọng. Nhờ đó, NGFW có thể đưa ra các quyết định ngăn chặn thông minh và chủ động hơn, nâng cao đáng kể hiệu quả phòng thủ mạng.

Tích hợp với hệ thống bảo vệ thiết bị đầu cuối (Endpoint Protection/EDR/XDR)

Tường lửa NGFW chủ yếu kiểm soát lưu lượng ở biên mạng, nhưng không có khả năng theo dõi và giám sát sâu vào từng thiết bị đầu cuối – nơi thường là điểm khởi phát của các cuộc tấn công. Do đó, việc tích hợp với hệ thống bảo vệ thiết bị đầu cuối như EDR (Endpoint Detection and Response) hoặc XDR

(Extended Detection and Response) là rất cần thiết. Khi một thiết bị có dấu hiệu nhiễm mã độc, hệ thống có thể phối hợp giữa NGFW và EDR để cô lập ngay thiết bị đó khỏi mạng, tránh lây lan sang các hệ thống khác. Ngoài ra, NGFW còn có thể đồng bộ với thông tin người dùng từ thiết bị để áp dụng chính sách truy cập chi tiết và cá nhân hóa hơn. Việc kết hợp này mang lại khả năng bảo vệ toàn diện, từ biên mạng cho đến từng điểm cuối trong hệ thống.

Tích hợp tự động hóa (Automation) và phản ứng sự cố (SOAR, Playbook)

Số lượng cảnh báo và sự kiện bảo mật ngày càng lớn, việc xử lý thủ công trở nên chậm chạp, dễ sai sót và không đáp ứng kịp thời. Đó là lý do tại sao NGFW hiện đại cần được tích hợp với các nền tảng tự động hóa như SOAR (Security Orchestration, Automation and Response). Thông qua các kịch bản (playbook) được định sẵn, NGFW có thể tự động phản ứng với mối đe dọa ngay khi phát hiện: ví dụ như chặn IP độc hại, khóa tài khoản người dùng, cô lập thiết bị hoặc gửi cảnh báo đến hệ thống quản trị sự kiện (SIEM). Điều này không chỉ rút ngắn thời gian phát hiện và xử lý sự cố, mà còn giúp nâng cao hiệu quả giám sát mạng và giảm gánh nặng cho đội ngũ vận hành bảo mật. Tự động hóa là bước quan trọng để chuyển từ bảo mật thụ động sang chủ động, thông minh và nhanh nhạy hơn.

1.12. Kết luận chương

Tường lửa là thành phần không thể thiếu trong hệ thống bảo mật mạng. Việc lựa chọn và triển khai tường lửa phù hợp với quy mô, nhu cầu và ngân sách của doanh nghiệp là yếu tố quyết định đến hiệu quả bảo vệ hệ thống thông tin. Trong các chương tiếp theo, chúng ta sẽ đi sâu vào việc thiết kế kiến trúc và triển khai thực tế hệ thống tường lửa thế hệ mới trong mô hình mạng doanh nghiệp.

CHƯƠNG II: THIẾT KẾ KIẾN TRÚC HỆ THỐNG TƯỜNG LỬA CHO DOANH NGHIỆP

2.1. Phân tích môi trường và yêu cầu bảo mật

2.1.1. Mô hình doanh nghiệp

Công ty ABC hoạt động trong lĩnh vực phát triển phần mềm và dịch vụ CNTT, với 300 nhân viên phân bố như sau:

Trụ sở chính: TP. Hồ Chí Minh – 200 nhân viên.

Chi nhánh: Hà Nội – 50 nhân viên.

Nhân viên làm việc từ xa: 50 người.

Cơ sở hạ tầng CNTT bao gồm các máy chủ quan trọng như Web server, Database server, Email server, File server,... phục vụ các tác vụ nội bộ cũng như bên ngoài.

2.1.2. Yêu cầu bảo mật

Do đặc thù công việc, hệ thống cần đảm bảo:

Kiểm soát và bảo vệ truy cập Internet cho người dùng nội bộ.

Bảo vệ dịch vụ công khai khỏi các cuộc tấn công bên ngoài.

Ngăn chặn truy cập trái phép vào dữ liệu nội bộ.

Hỗ trợ VPN an toàn cho nhân viên làm việc từ xa và chi nhánh.

Giám sát và ghi log toàn bộ lưu lượng truy cập phục vụ phân tích.

2.2. Yêu cầu thiết kế hệ thống tường lửa

2.2.1. Mục tiêu thiết kế

Thiết lập kiến trúc phân vùng bảo mật rõ ràng.

Tách biệt lưu lượng giữa người dùng, máy chủ, dịch vụ công khai và Internet.

Cho phép kiểm soát truy cập chi tiết đến từng vùng mạng.

Đảm bảo hiệu năng cao, dễ mở rộng, hỗ trợ VPN linh hoạt.

Triển khai giải pháp có khả năng phát hiện & ngăn chặn tấn công chủ động.

2.2.2. Yêu cầu kỹ thuật

Hỗ trợ các chức năng như: NAT, ACL, VPN, IPS, Application Control, URL Filtering.

Đảm bảo khả năng log và phân tích lưu lượng theo thời gian thực.

Hỗ trợ HA (High Availability) để tránh gián đoạn dịch vụ.

2.3. Thiết kế phân vùng bảo mật (Security Zones)

Hệ thống mạng được chia thành các vùng bảo mật chính như sau:

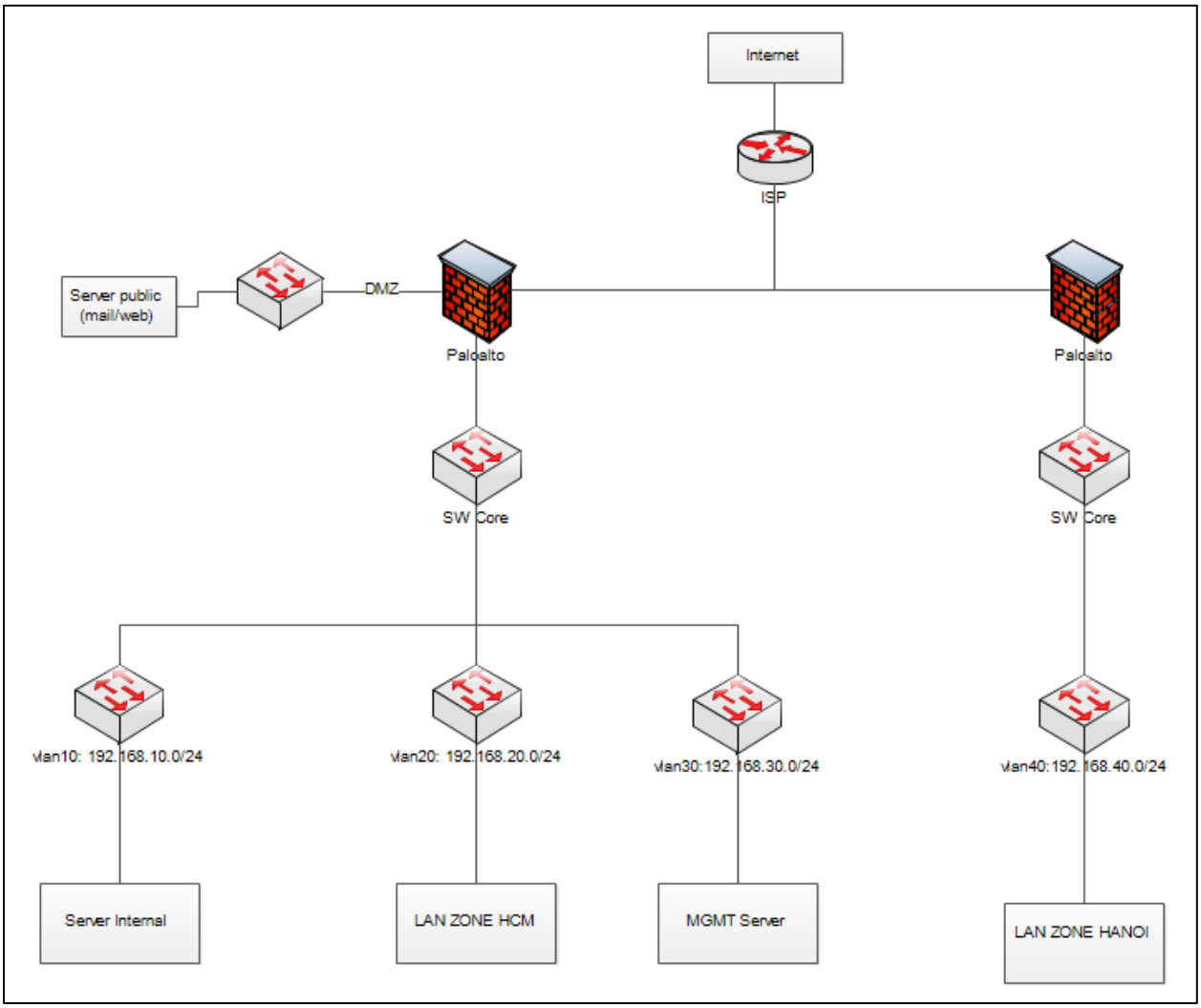
Vùng bảo mật	Chức năng
WAN	Mạng Internet, không đáng tin cậy
LAN_HCM	Nhân viên làm việc tại TP.HCM
LAN_HN	Nhân viên làm việc tại Hà Nội
SERVER	Máy chủ nội bộ, cơ sở dữ liệu, tệp tin
DMZ	Vùng chứa dịch vụ công khai (web, mail)
MANAGEMENT	Quản trị firewall và các thiết bị mạng
VPN	Người dùng từ xa, kết nối bảo mật thông qua Internet

Việc phân vùng rõ ràng này cho phép triển khai chính sách tường lửa cụ thể cho từng vùng, giảm thiểu rủi ro và ngăn chặn lây lan nếu bị tấn công.

2.4. Kiến trúc triển khai thực tế

2.4.1. Tổng quan sơ đồ hệ thống

Dưới đây là mô hình mạng thực tế được mô phỏng:



Các thành phần chính:

2 thiết bị tường lửa Palo Alto (PA-VM10.0.1-1 và PA-VM10.0.1-2) cấu hình HA.

Switch CORE làm trung tâm kết nối các vùng mạng.

Các switch access kết nối vùng LAN, SERVER, DMZ, MANAGEMENT.

VPCS mô phỏng người dùng và thiết bị đầu cuối.

Cloud (MGMT1, MGMT2): quản trị firewall qua VMnet8 từ máy vật lý.

2.4.2. Phân tích chức năng từng vùng

Ký hiệu sơ đồ	Zone bảo mật	Chức năng sử dụng
INTERNET	WAN	Kết nối Internet
PA-VM	NGFW	Kiểm soát và lọc truy cập
DMZ	DMZ	Máy chủ cung cấp dịch vụ công khai
SERVER_INTERNAL	Server	Máy chủ nội bộ (DB, File)
LAN_HCM	LAN (HCM)	Người dùng văn phòng HCM
LAN_HN	LAN (HN)	Người dùng văn phòng Hà Nội
MGMT1/MGMT2	Management	Quản lý firewall

2.5. Cấu trúc VLAN và phân mạng

Việc triển khai VLAN giúp tách biệt lưu lượng giữa các vùng mạng. Cấu trúc VLAN được phân như sau:

VLAN	Dải IP	Khu vực
10	192.168.10.0/24	Server nội bộ
20	192.168.20.0/24	Server mở rộng
30	192.168.30.0/24	LAN TP.HCM
40	192.168.40.0/24	LAN Hà Nội và quản trị

2.6. Lựa chọn giải pháp tường lửa NGFW

2.6.1. Giải pháp sử dụng

Giải pháp sử dụng là Palo Alto Firewall (phiên bản máy ảo PA-VM), được triển khai theo dạng HA để đảm bảo tính liên tục.

2.6.2. Lý do lựa chọn

Tiêu chí	Đáp ứng từ Palo Alto
Khả năng bảo mật nâng cao	Tích hợp IPS, Antivirus, URL Filtering
Kiểm soát ứng dụng chi tiết	Hỗ trợ App-ID, User-ID
Dễ triển khai và quản trị	Giao diện web trực quan, cấu hình linh hoạt
Khả năng phân tích & log mạnh	Tích hợp Threat Logs, Traffic Logs
Hỗ trợ VPN đầy đủ	Site-to-site IPsec và Remote Access VPN

Chương 3: TRIỂN KHAI VÀ CẤU HÌNH HỆ THỐNG TƯỜNG LỬA

3.1.Cấu hình Routing, NAT

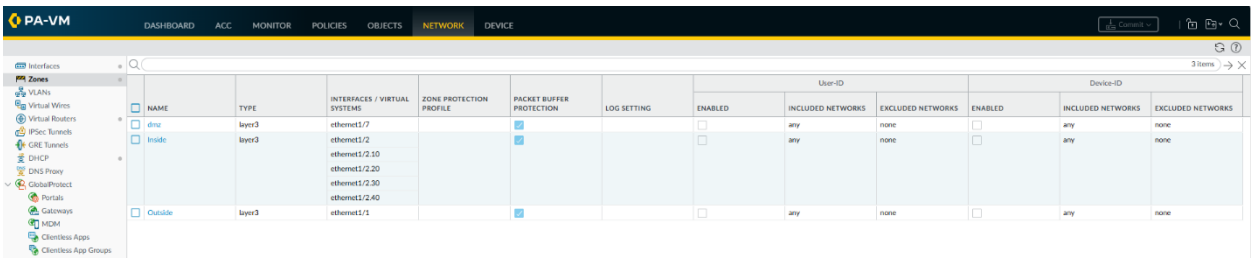
3.1.1.Cấu hình Zone:

Zone trong tường lửa giúp phân chia mạng thành các khu vực logic riêng biệt, từ đó dễ dàng kiểm soát luồng lưu lượng và áp dụng các chính sách bảo mật khác nhau. Trong mô hình này, ta tạo 3 zone:

-DMZ: Chứa dịch vụ công khai (Web, Mail Server), cho phép truy cập từ Internet nhưng được giám sát.

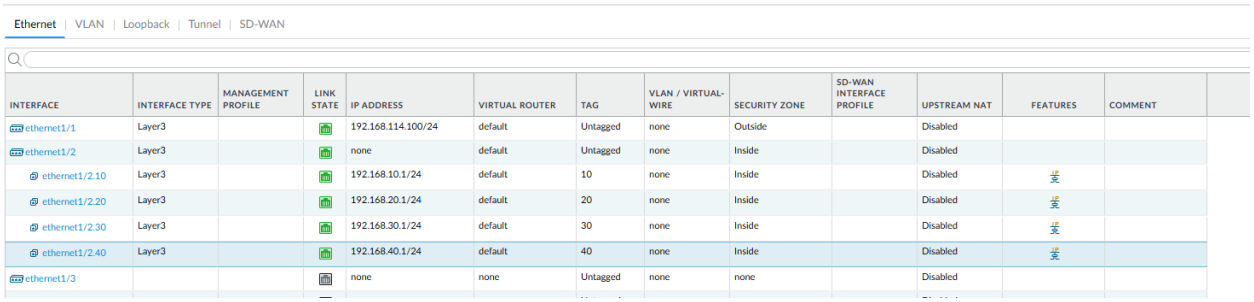
-Inside: Mạng nội bộ nhân viên, ưu tiên bảo mật và hạn chế truy cập từ ngoài.

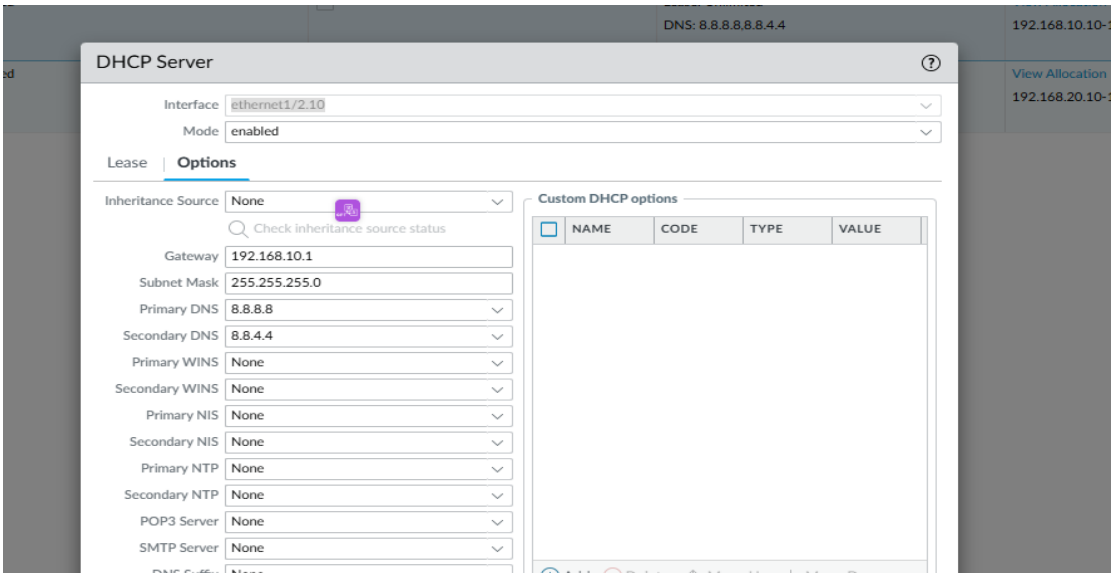
-Outside: Đại diện cho mạng Internet hoặc các kết nối không tin cậy.



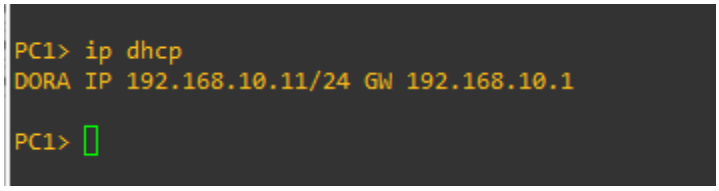
3.1.2.Cấu hình Interface và DHCP:

Interface giúp kết nối tường lửa với các mạng vật lý. DHCP Server cấp phát IP tự động cho thiết bị trong zone Inside và DMZ.





Thiết bị trong mạng Inside/DMZ nhận IP tự động và kết nối được đến gateway của tường lửa:



3.1.3.Cấu hình NAT Policy:

NAT (Network Address Translation) cho phép máy trong mạng nội bộ truy cập Internet bằng cách chuyển đổi địa chỉ IP private thành public.

			Original Packet						Translated Packet		Rule Usage			
	NAME	TAGS	SOURCE ZONE	DESTINATION ZONE	DESTINATION INTERFACE	SOURCE ADDRESS	DESTINATION ADDRESS	SERVICE	SOURCE TRANSLATION	DESTINATION TRANSLATION	HIT COUNT	LAST HIT	FIRST HIT	MODIFIED
1	inside_to_outside	none	Inside	Outside	ethernet1/1	any	any	any	dynamic-ip-and-port ethernet1/1 192.168.114.100/24	none	11	2025-08-06 23:32:07	2025-08-06 23:32:07	2025-08-0

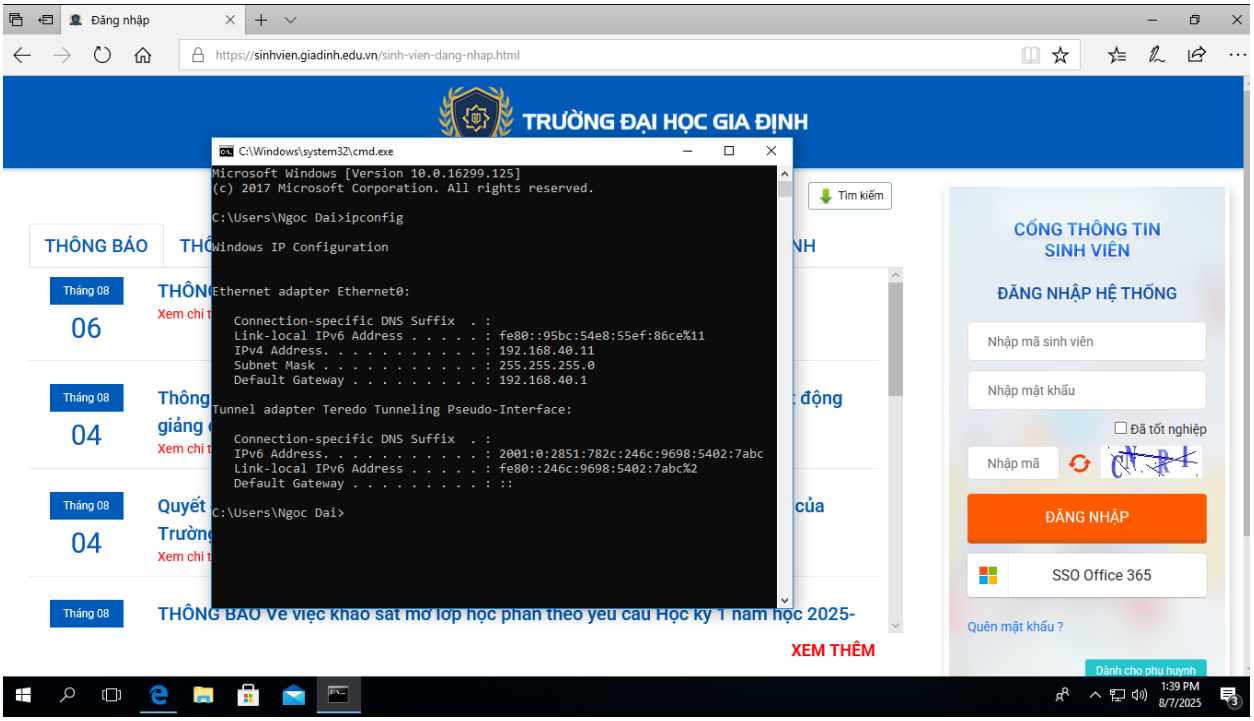
3.1.4.Cấu hình Secutiry Policy:

Security Policy là tập hợp các quy tắc quyết định lưu lượng được phép hay bị chặn giữa các zone.

5 items

				Source				Destination								
	NAME	TAGS	TYPE	ZONE	ADDRESS	USER	DEVICE	ZONE	ADDRESS	DEVICE	APPLICATION	SERVICE	ACTION	PROFILE	OPTIONS	HIT COUNT
1	access_internet_inside	none	universal	Inside	any	any	any	Outside	any	any	any	any	Allow	none		189
2	access_internet	none	universal	dmz	any	any	any	Outside	any	any	any	any	Allow	none		11003
3	ping	none	universal	Inside	any	any	any	Inside	any	any	ping	application-d...	Allow	none		55
4	intrazone-default	none	intrazone	any	any	any	any	(intrazone)	any	any	any	any	Allow	none	none	9
5	interzone-default	none	interzone	any	any	any	any	any	any	any	any	any	Deny	none	none	0

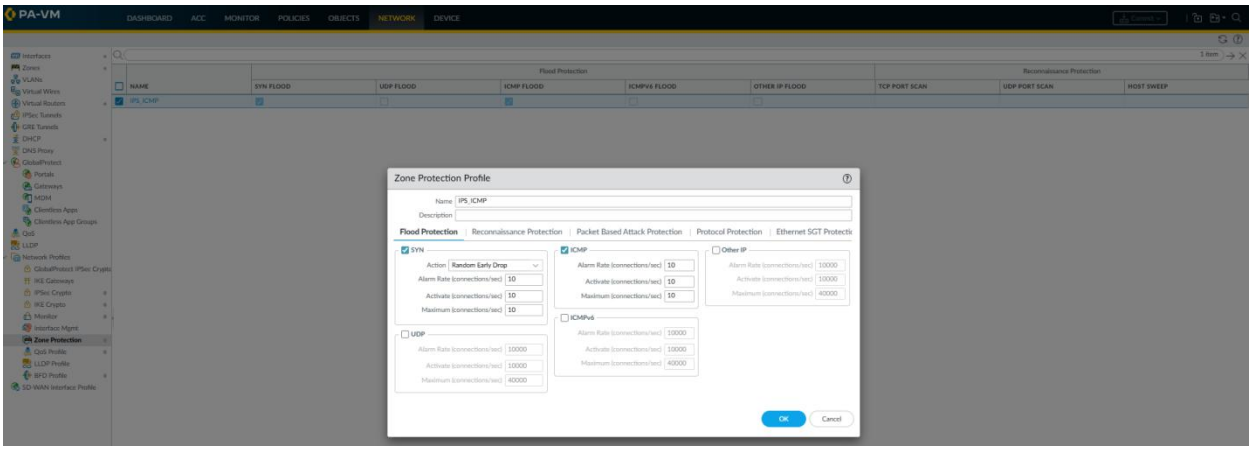
Inside truy cập được internet:

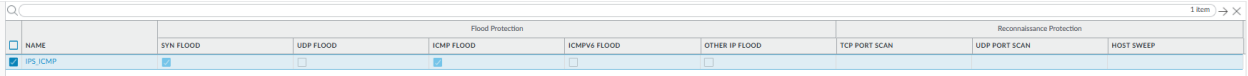


3.2.IPS Policy

IPS (Intrusion Prevention System) là tính năng phát hiện và ngăn chặn các cuộc tấn công mạng theo thời gian thực. Palo Alto sử dụng Zone Protection Profile để bảo vệ các zone khỏi các mối đe dọa như DoS/DDoS, quét cổng, hoặc gói tin bất thường.

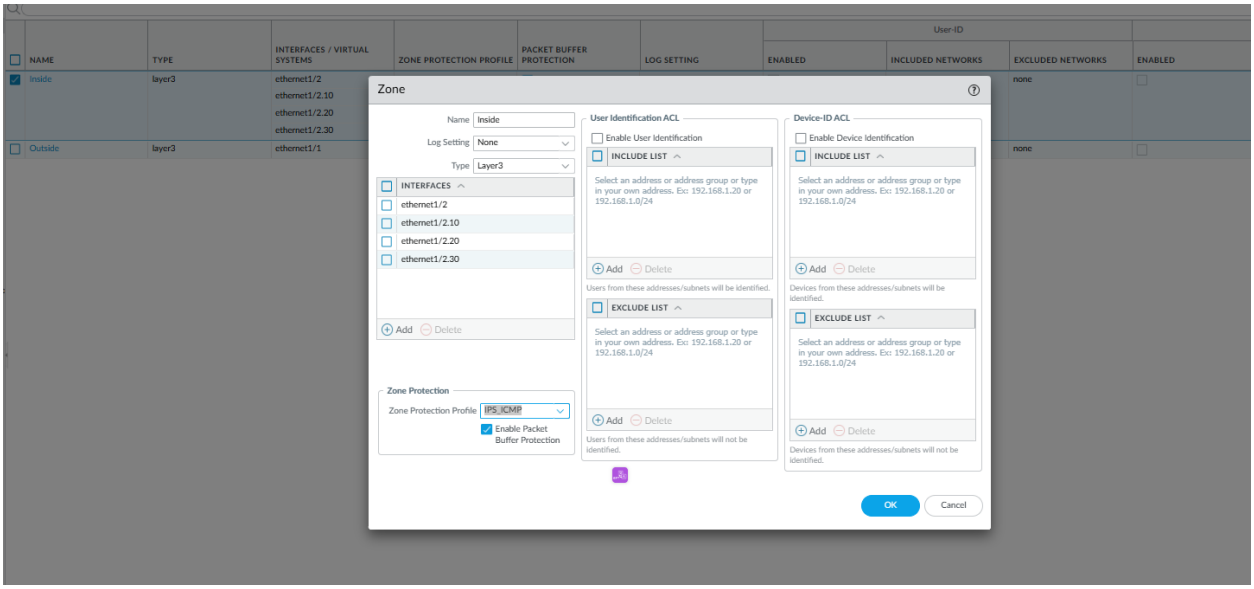
Vào Network → Network Profiles → Zone Protection.



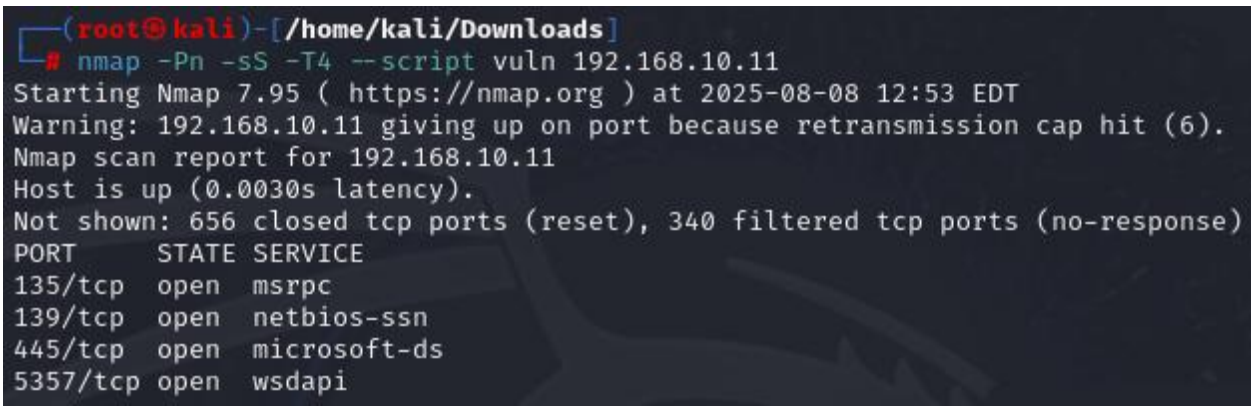


NAME	Flood Protection					Reconnaissance Protection		
	SYN FLOOD	UDP FLOOD	ICMP FLOOD	ICMPV6 FLOOD	OTHER IP FLOOD	TCP PORT SCAN	UDP PORT SCAN	HOST SWEEP
IPS_ICMP	✓		✓					

Vào Zone cần bảo vệ khỏi những bên ngoài và add phần Zone Protection Profile vào:

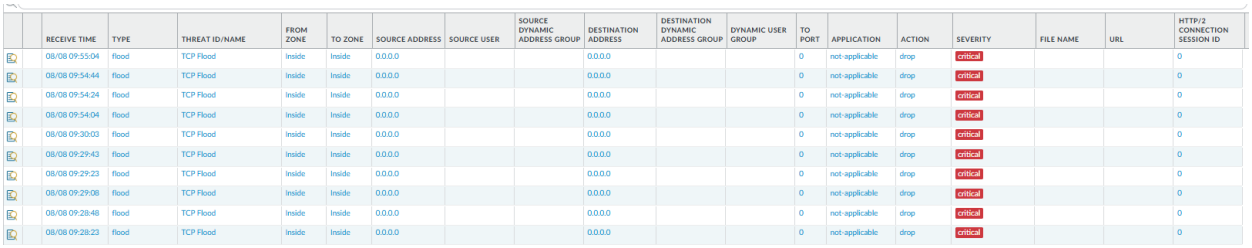


Thử nghiệm: Thực hiện quét cổng bằng nmap từ ngoài vào zone được bảo vệ.



```
┌──(root㉿kali)-[/home/kali/Downloads]
└─# nmap -Pn -sS -T4 --script vuln 192.168.10.11
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-08 12:53 EDT
Warning: 192.168.10.11 giving up on port because retransmission cap hit (6).
Nmap scan report for 192.168.10.11
Host is up (0.0030s latency).
Not shown: 656 closed tcp ports (reset), 340 filtered tcp ports (no-response)
PORT     STATE SERVICE
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
5357/tcp open  wsdapi
```

Hệ thống phát hiện và chặn lưu lượng quét, tấn công DoS vào zone được bảo vệ.



RECEIVE TIME	TYPE	THREAT ID/NAME	FROM ZONE	TO ZONE	SOURCE ADDRESS	SOURCE USER	SOURCE DYNAMIC ADDRESS GROUP	DESTINATION ADDRESS	DESTINATION DYNAMIC ADDRESS GROUP	DYNAMIC USER GROUP	TO PORT	APPLICATION	ACTION	SEVERITY	FILE NAME	URL	HTTP/2 CONNECTION SESSION ID
08/08 09:55:04	flood	TCP Flood	inside	inside	0.0.0.0			0.0.0.0			0	not-applicable	drop	critical			0
08/08 09:54:44	flood	TCP Flood	inside	inside	0.0.0.0			0.0.0.0			0	not-applicable	drop	critical			0
08/08 09:54:24	flood	TCP Flood	inside	inside	0.0.0.0			0.0.0.0			0	not-applicable	drop	critical			0
08/08 09:54:04	flood	TCP Flood	inside	inside	0.0.0.0			0.0.0.0			0	not-applicable	drop	critical			0
08/08 09:30:03	flood	TCP Flood	inside	inside	0.0.0.0			0.0.0.0			0	not-applicable	drop	critical			0
08/08 09:29:43	flood	TCP Flood	inside	inside	0.0.0.0			0.0.0.0			0	not-applicable	drop	critical			0
08/08 09:29:23	flood	TCP Flood	inside	inside	0.0.0.0			0.0.0.0			0	not-applicable	drop	critical			0
08/08 09:29:08	flood	TCP Flood	inside	inside	0.0.0.0			0.0.0.0			0	not-applicable	drop	critical			0
08/08 09:28:48	flood	TCP Flood	inside	inside	0.0.0.0			0.0.0.0			0	not-applicable	drop	critical			0
08/08 09:28:23	flood	TCP Flood	inside	inside	0.0.0.0			0.0.0.0			0	not-applicable	drop	critical			0

```
admin@PA-VM> show log threat
Time                App             From                        Src Port        Source
Rule                Action          To                          Dst Port        Destination
Severity            Src User                    Dst User                        Threat          Pcap_id
Rule_UUid
================================================================================================
2025/08/08 11:29:45 not-applicable  Inside                      0               0.0.0.0
(null)              drop            Inside                      0               0.0.0.0
critical            (null)                      (null)                          TCP Flood(8501) 0

2025/08/08 11:30:05 not-applicable  Inside                      0               0.0.0.0
(null)              drop            Inside                      0               0.0.0.0
critical            (null)                      (null)                          TCP Flood(8501) 0
```

3.3.SSL Policy

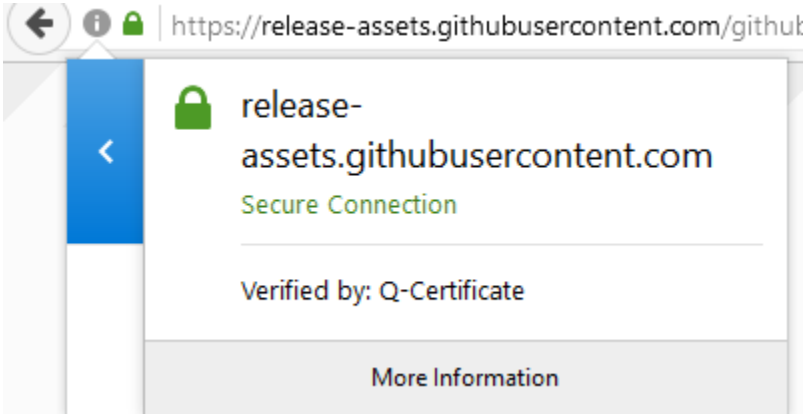
SSL Decryption cho phép tường lửa giải mã lưu lượng HTTPS để kiểm tra và áp dụng chính sách bảo mật. Điều này cần thiết vì phần lớn lưu lượng hiện nay được mã hóa.

				Source				Destination				
	NAME	TAGS	TYPE	ZONE	ADDRESS	USER	DEVICE	ZONE	ADDRESS	DEVICE	APPLICATION	SERVICE
1	Outside_Decrypt	none	universal	Inside	any	any	any	Outside	any	any	any	any

Device Certificates | Default Trusted Certificate Authorities

1 item

NAME	SUBJECT	ISSUER	CA	KEY	EXPIRES	STATUS	ALGORITHM	USAGE
SSL-CERT	C = SA, CN = Q-Certificate	C = SA, CN = Q-Certificate	✓	✓	Aug 8 15:05:14 2026 GMT	valid	RSA	Forward Trust Certificate Forward Untrust Certificate Trusted Root CA Certificate

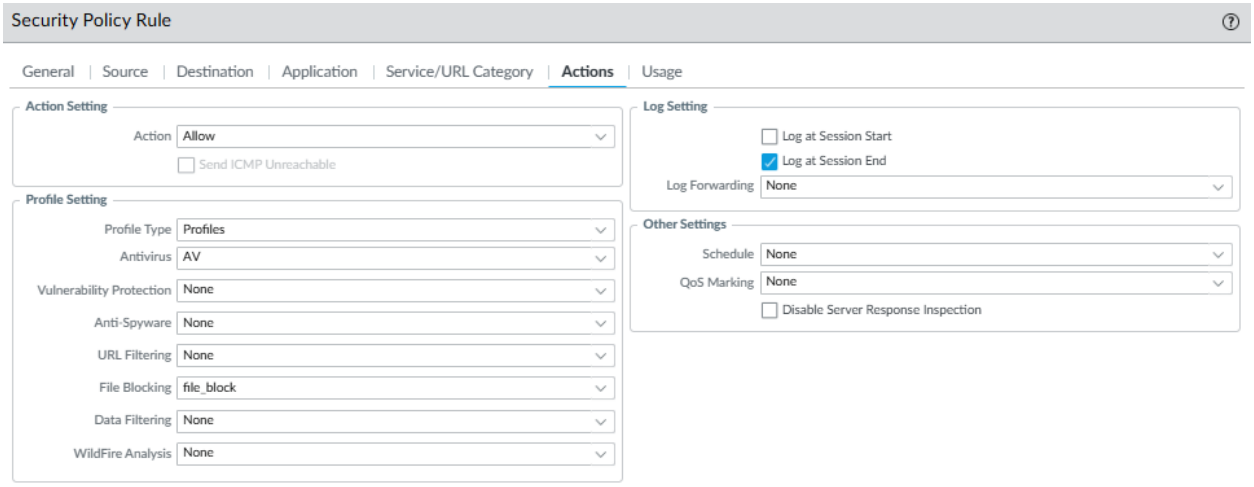


3.4.File and Malware Policy

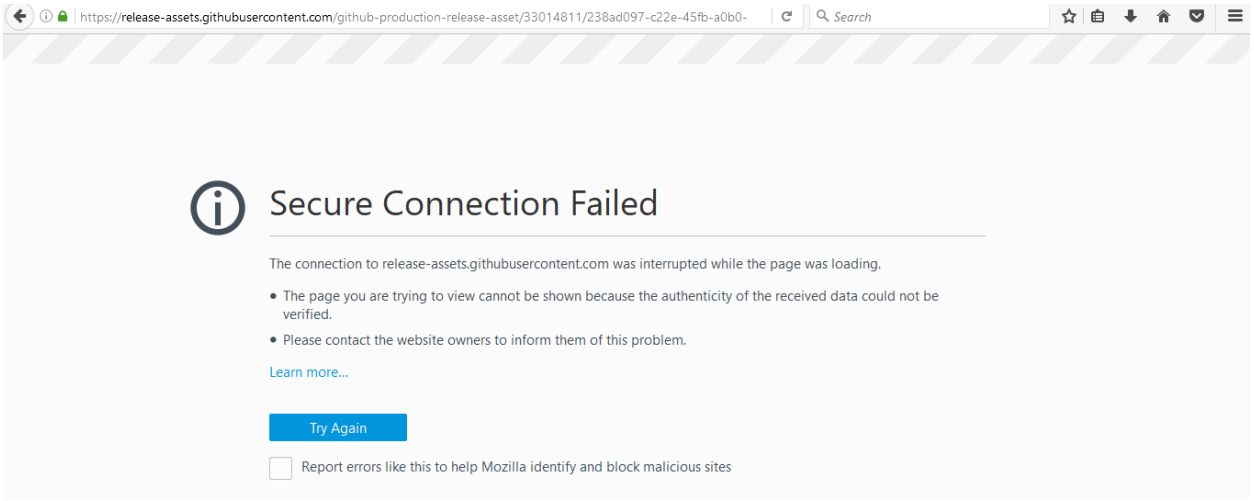
Chặn hoặc cảnh báo khi tải lên/xuống các file nguy hiểm, đồng thời quét mã độc trong lưu lượng mạng.

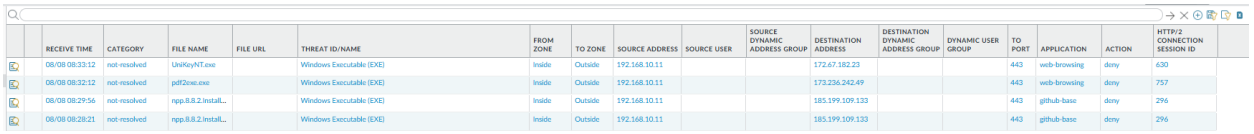
File:

Trong phần File Blocking chọn file_block (nơi chứa các định dạng file mà bạn block)



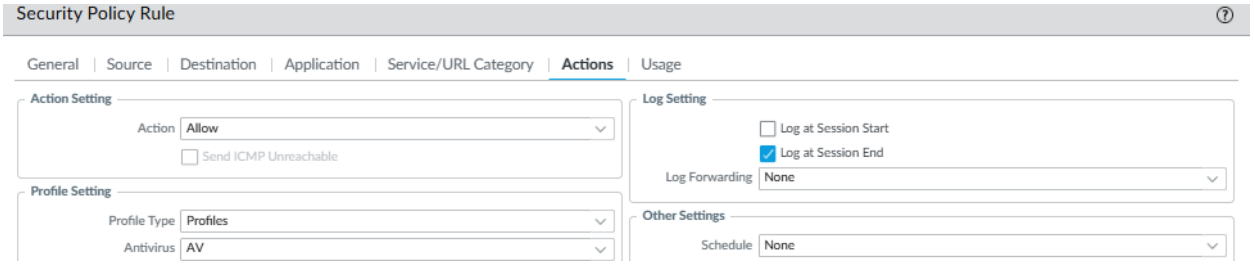
Tường lửa chặn tải file nguy hiểm và cảnh báo trong log Threat.

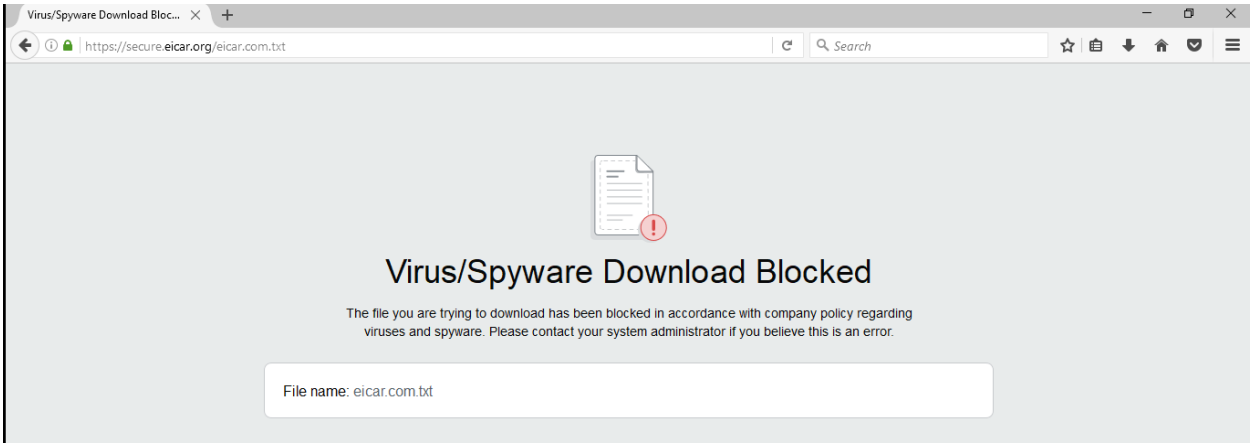




RECEIVE TIME	CATEGORY	FILE NAME	FILE URL	THREAT ID/NAME	FROM ZONE	TO ZONE	SOURCE ADDRESS	SOURCE USER	SOURCE DYNAMIC ADDRESS GROUP	DESTINATION ADDRESS	DESTINATION DYNAMIC ADDRESS GROUP	DYNAMIC USER GROUP	TO PORT	APPLICATION	ACTION	HTTP/2 CONNECTION SESSION ID
08/08 08:33:12	not-resolved	UniKeyNT.exe		Windows Executable (EXE)	Inside	Outside	192.168.10.11			172.67.182.23			443	web-browsing	deny	630
08/08 08:32:12	not-resolved	pdf2exp.exe		Windows Executable (EXE)	Inside	Outside	192.168.10.11			173.236.242.49			443	web-browsing	deny	757
08/08 08:29:56	not-resolved	npp.8.8.2.Install...		Windows Executable (EXE)	Inside	Outside	192.168.10.11			185.199.109.133			443	github-base	deny	296
08/08 08:28:21	not-resolved	npp.8.8.2.Install...		Windows Executable (EXE)	Inside	Outside	192.168.10.11			185.199.109.133			443	github-base	deny	296

Malware:

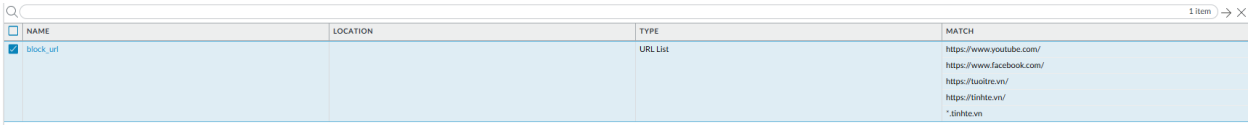




3.5.URL Filtering

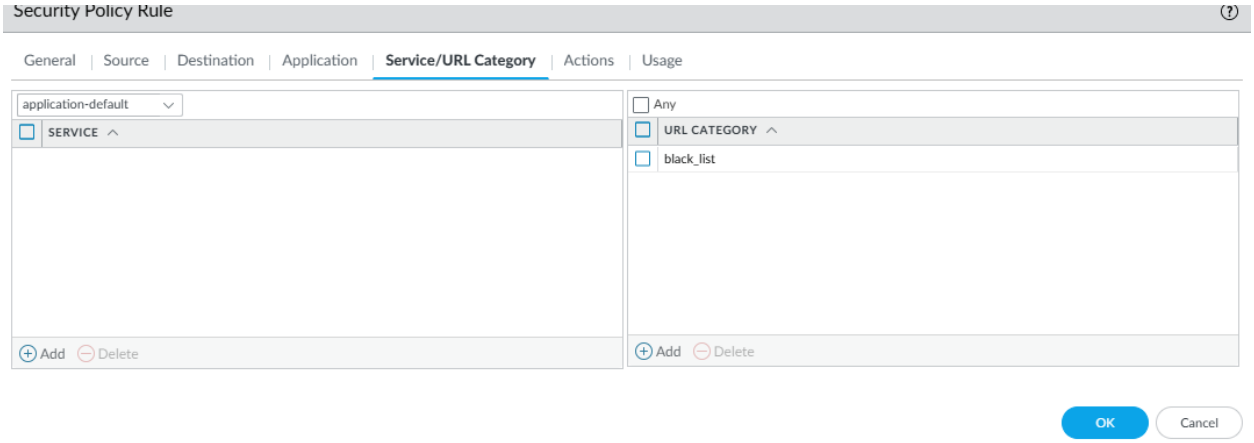
Cho phép hoặc chặn truy cập website dựa trên danh mục (category) nhằm ngăn người dùng truy cập web không an toàn hoặc không phù hợp.

Tạo trước 1 url category

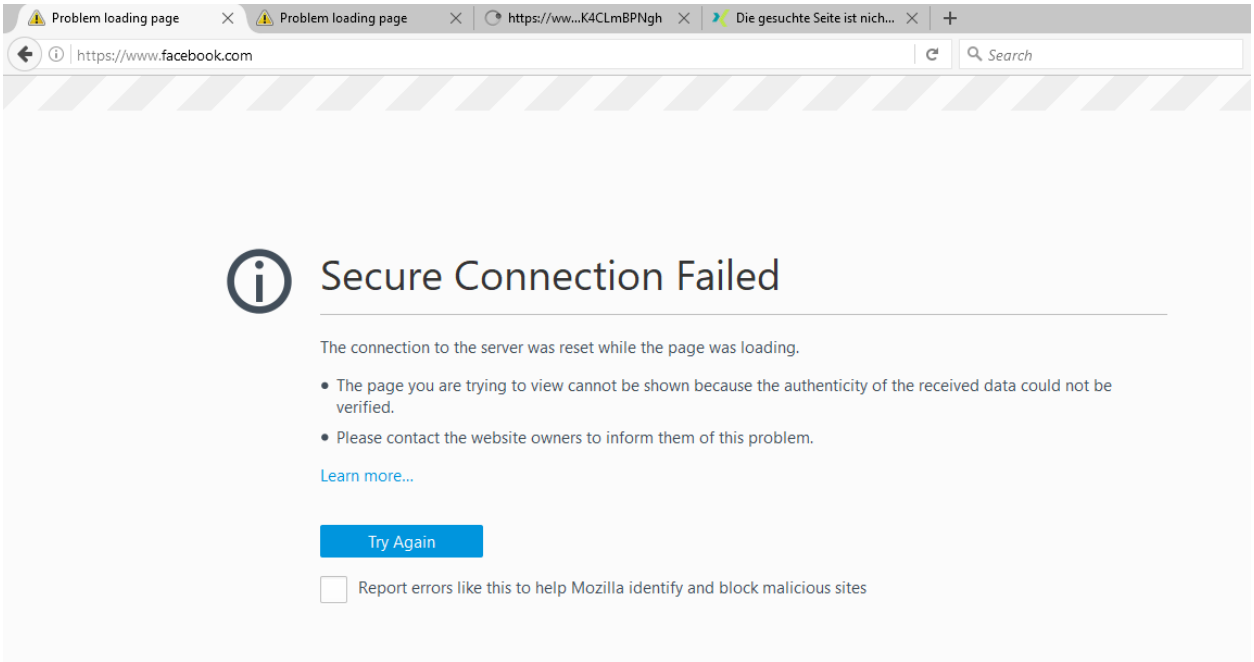


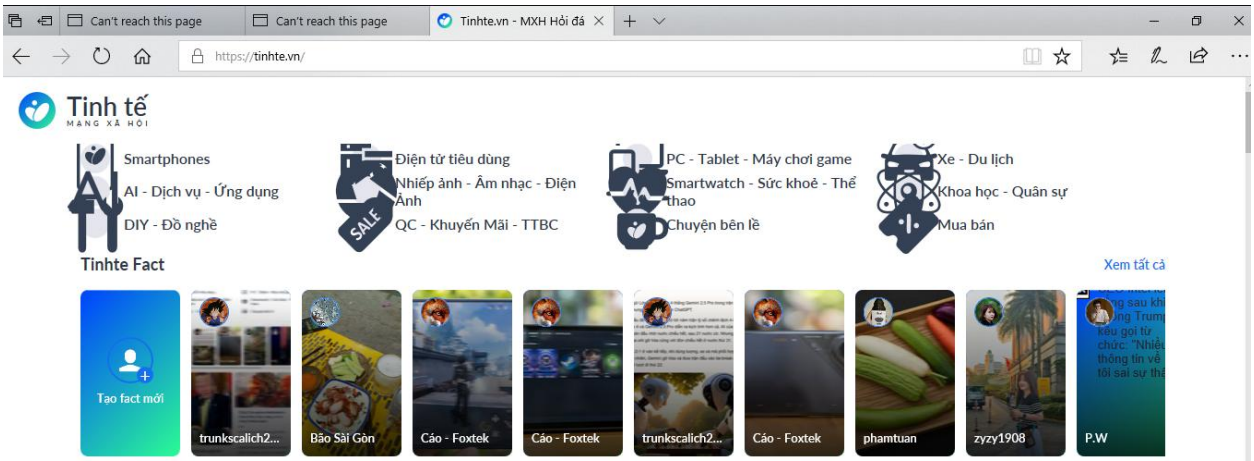
Tạo policy deny URL category

Tại tab Service/URL Category phần URL Category chọn danh sách vừa mới tạo và chọn Action Deny (Lưu ý để policy này ở trước Policy Internet)



Kiểm tra: Đã block đường web chỉ định và truy cập được các web khác

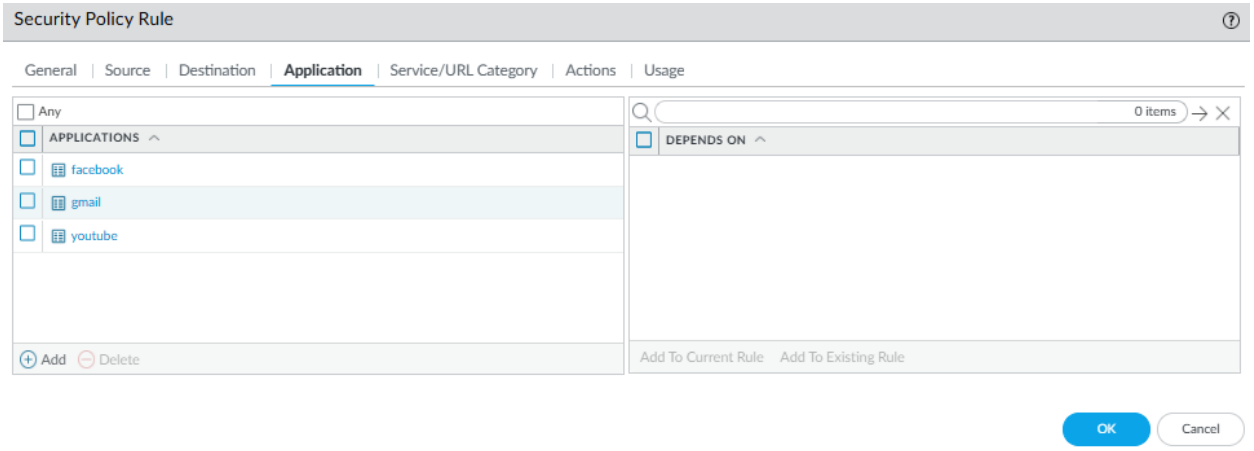




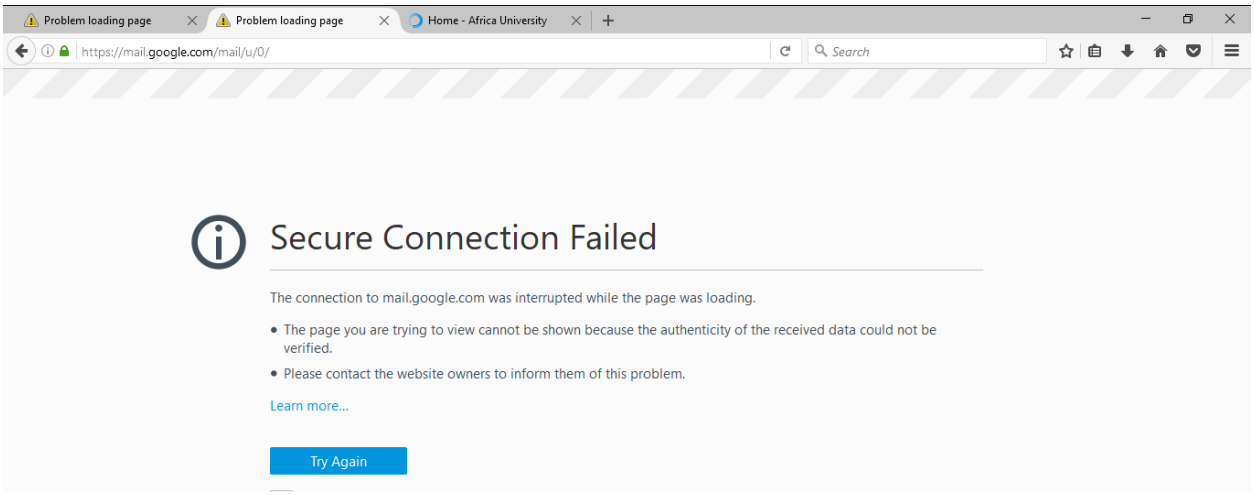
3.6.Application Control

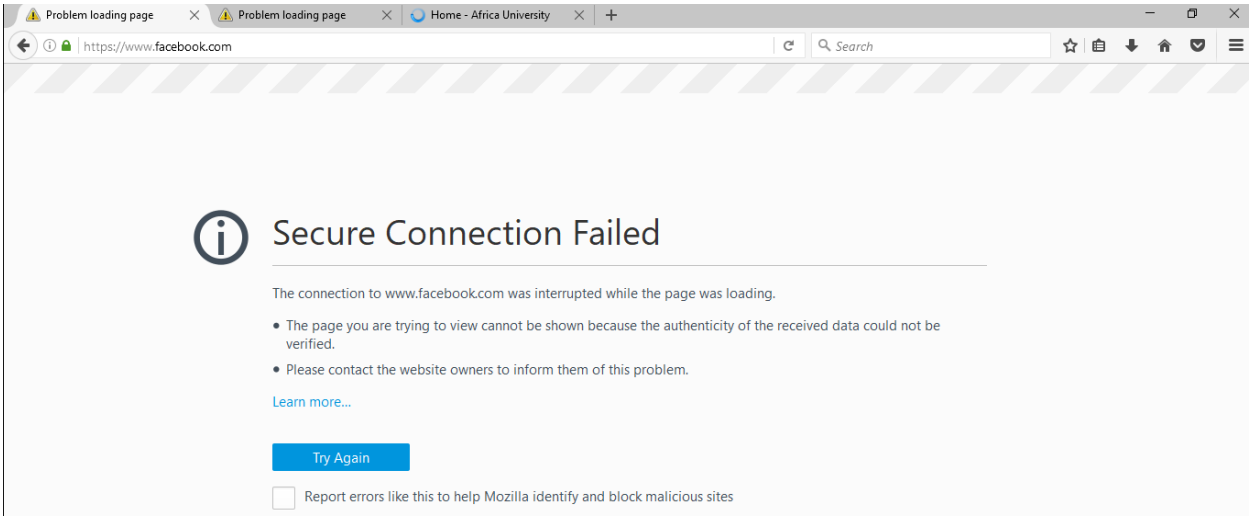
App-ID cho phép nhận diện và kiểm soát ứng dụng chạy qua tường lửa, kể cả khi sử dụng cổng hoặc giao thức bất thường.

Chặn App-ID Facebook & Youtube & Gmail



Kết quả: Truy cập Facebook/YouTube/Gmail → Bị chặn.

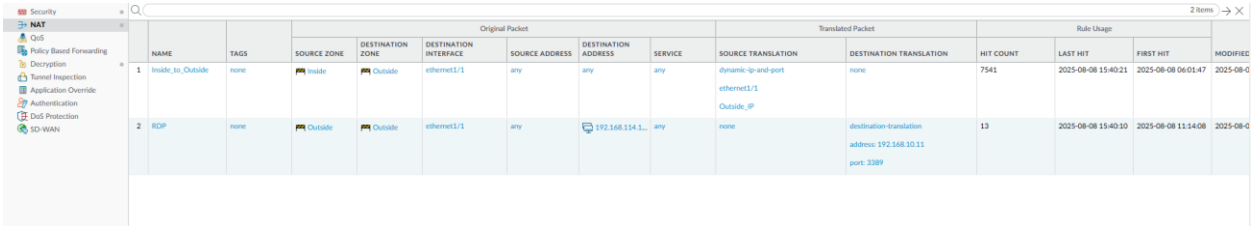




3.7.Cấu hình remote access cho người làm việc từ xa

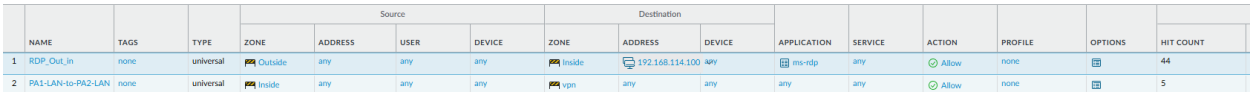
Cho phép nhân viên truy cập tài nguyên nội bộ từ xa qua VPN Remote Access, đảm bảo an toàn kết nối bằng mã hóa.

Cấu hình NAT Policy cho phép VPN Client truy cập Inside:



	NAME	TAGS	Original Packet						Translated Packet		Rule Usage			
			SOURCE ZONE	DESTINATION ZONE	DESTINATION INTERFACE	SOURCE ADDRESS	DESTINATION ADDRESS	SERVICE	SOURCE TRANSLATION	DESTINATION TRANSLATION	HIT COUNT	LAST HIT	FIRST HIT	MODIFIED
1	Inside_to_Outside	none	Inside	Outside	ethernet1/1	any	any	any	dynamic-ip-and-port ethernet1/1 Outside_IP	none	7541	2025-08-08 15:40:21	2025-08-08 06:01:47	2025-08-0
2	RDP	none	Outside	Outside	ethernet1/1	any	192.168.114.1...	any	none	destination-translation address: 192.168.10.11 port: 3389	13	2025-08-08 15:40:10	2025-08-08 11:14:08	2025-08-0

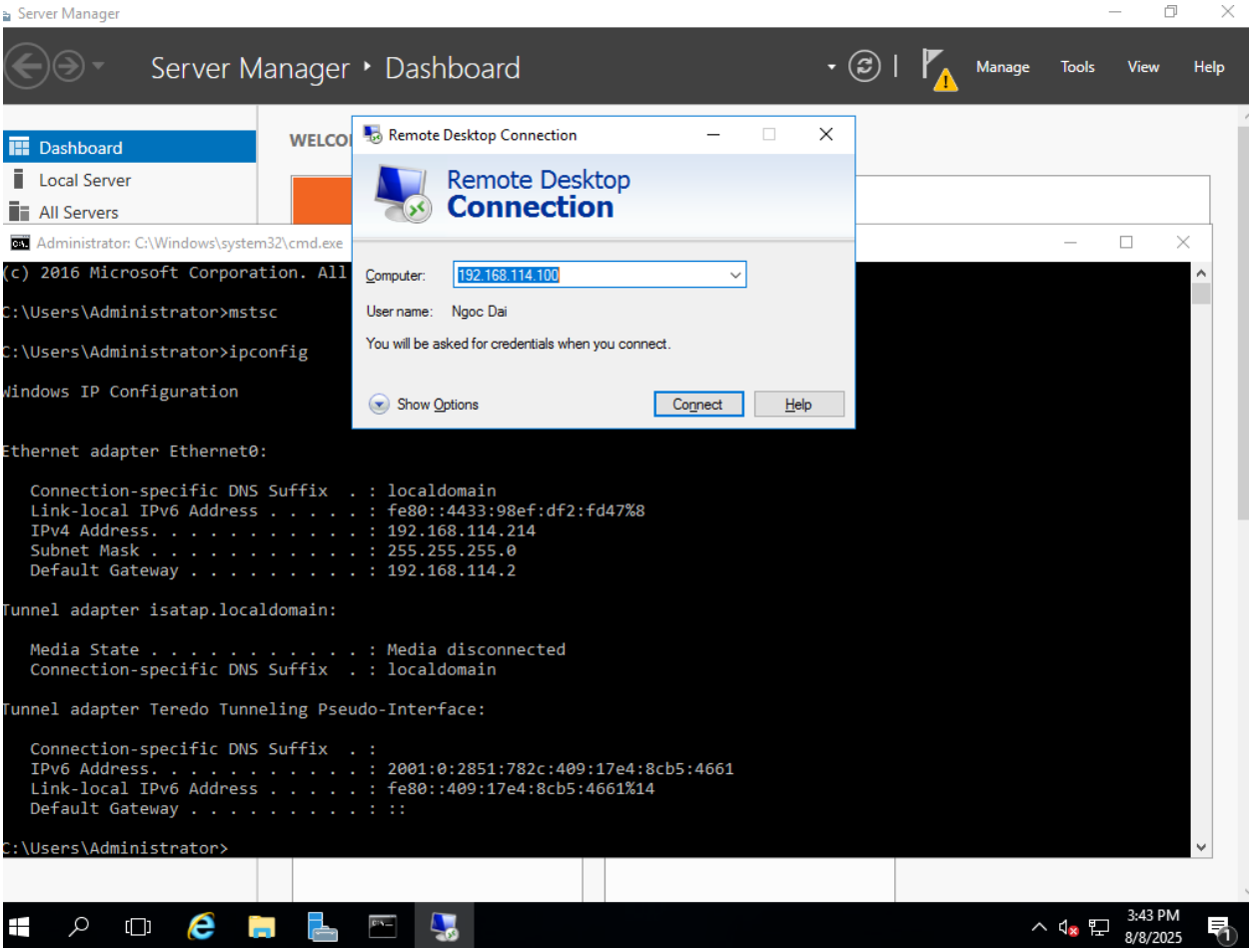
Tạo Security Policy từ zone VPN đến Inside.

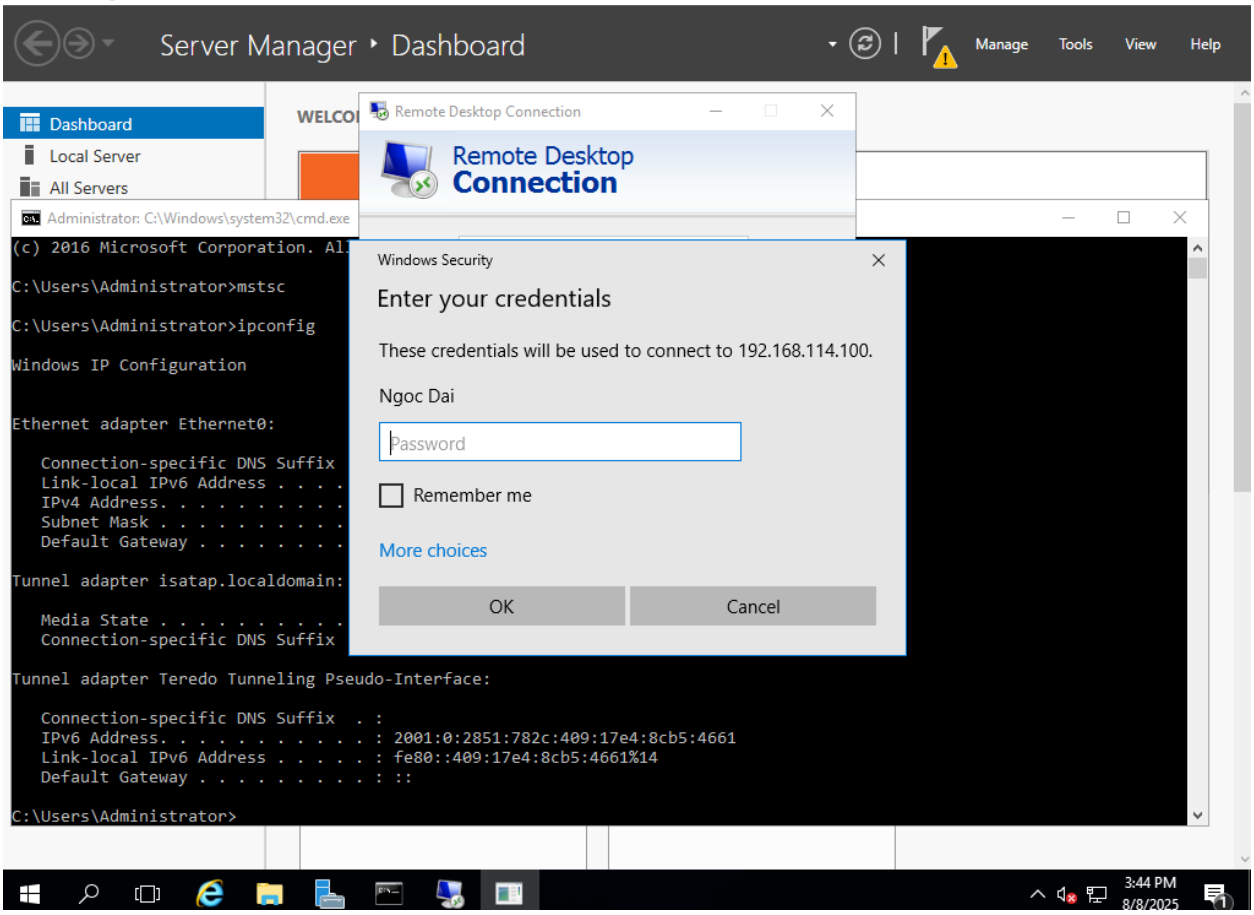


	NAME	TAGS	TYPE	Source				Destination			APPLICATION	SERVICE	ACTION	PROFILE	OPTIONS	HIT COUNT
				ZONE	ADDRESS	USER	DEVICE	ZONE	ADDRESS	DEVICE						
1	RDP_Out_in	none	universal	Outside	any	any	any	Inside	192.168.114.100	any	ms-rdp	any	Allow	none		44
2	PA1-LAN-to-PA2-LAN	none	universal	Inside	any	any	any	vpn	any	any	any	any	Allow	none		5

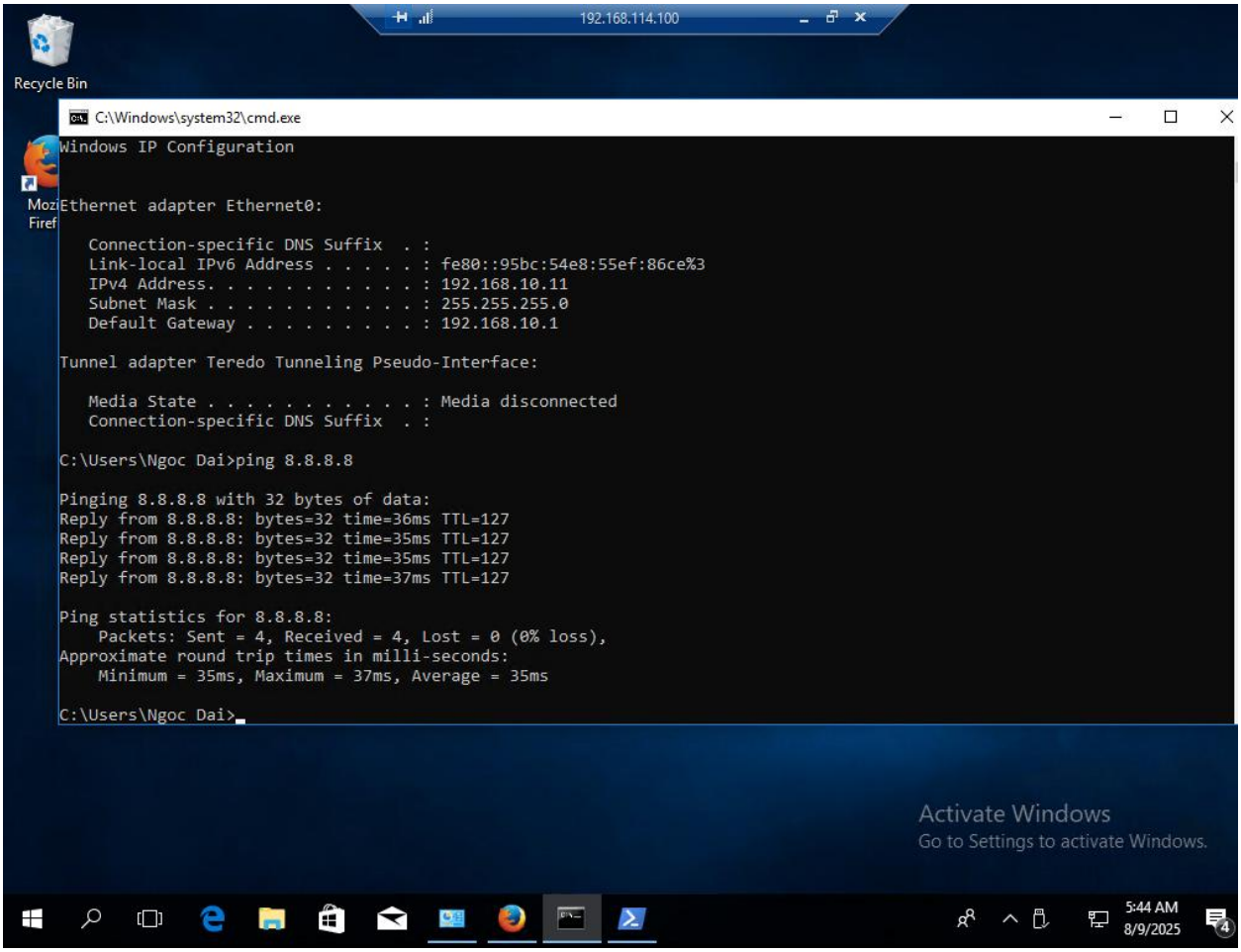
Kết quả:

Kết nối VPN từ máy client.




Server Manager ‣ Dashboard
Manage
Tools
View
Help
Dashboard
Local Server
All Servers
Remote Desktop Connection
Remote Desktop
Connection
Administrator: C:\Windows\system32\cmd.exe
(c) 2016 Microsoft Corporation. All
C:\Users\Administrator>mstsc
C:\Users\Administrator>ipconfig
Windows IP Configuration
Ethernet adapter Ethernet0:
Connection-specific DNS Suffix
Link-local IPv6 Address . . . .
IPv4 Address. . . . . .
Subnet Mask . . . . . .
Default Gateway . . . . . .
Tunnel adapter isatap.localdomain:
Media State . . . . . .
Connection-specific DNS Suffix
Tunnel adapter Teredo Tunneling Pseudo-Interface:
Connection-specific DNS Suffix . :
IPv6 Address. . . . . : 2001:0:2851:782c:409:17e4:8cb5:4661
Link-local IPv6 Address . . . . . : fe80::409:17e4:8cb5:4661%14
Default Gateway . . . . . : ::
C:\Users\Administrator>
Windows Security
Enter your credentials
These credentials will be used to connect to 192.168.114.100.
Ngoc Dai
Password
Remember me
More choices
OK
Cancel
3:44 PM
8/8/2025

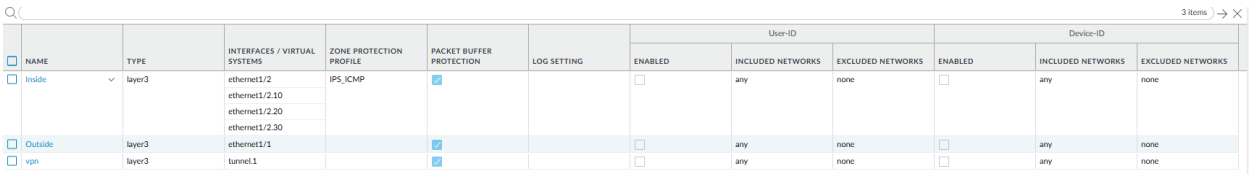
Ping đến server nội bộ.



3.8.VPN site to site:

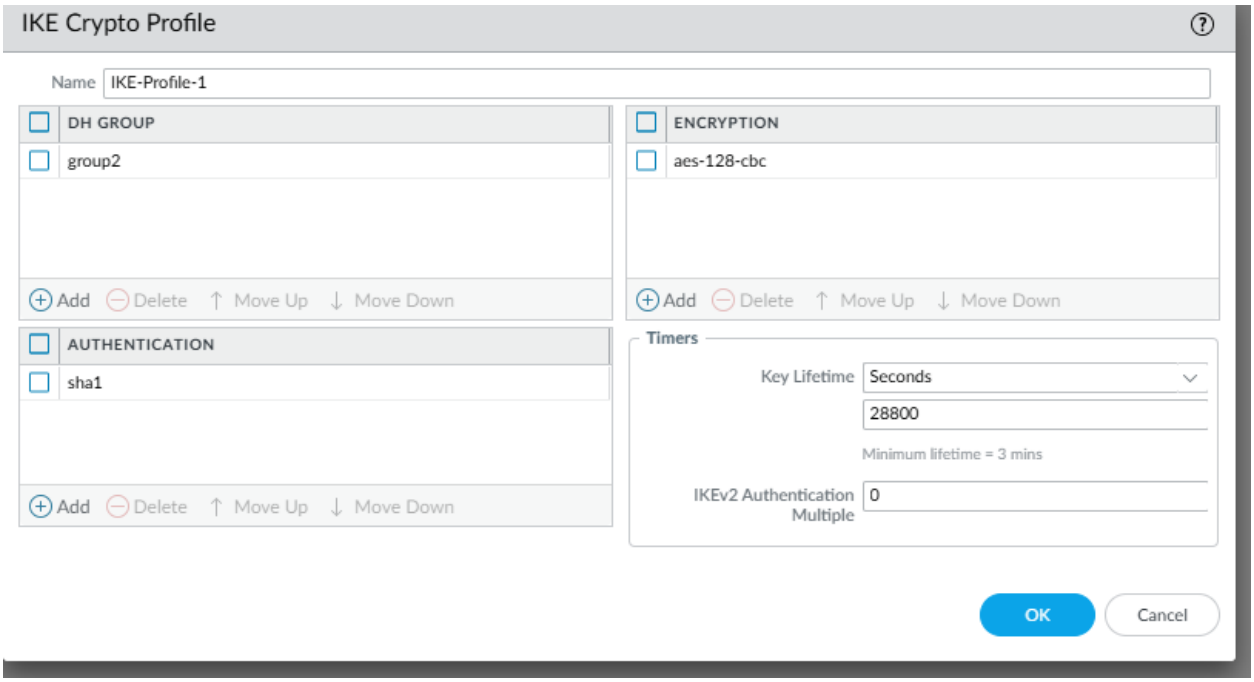
Trên PA1:

Tạo zone VPN

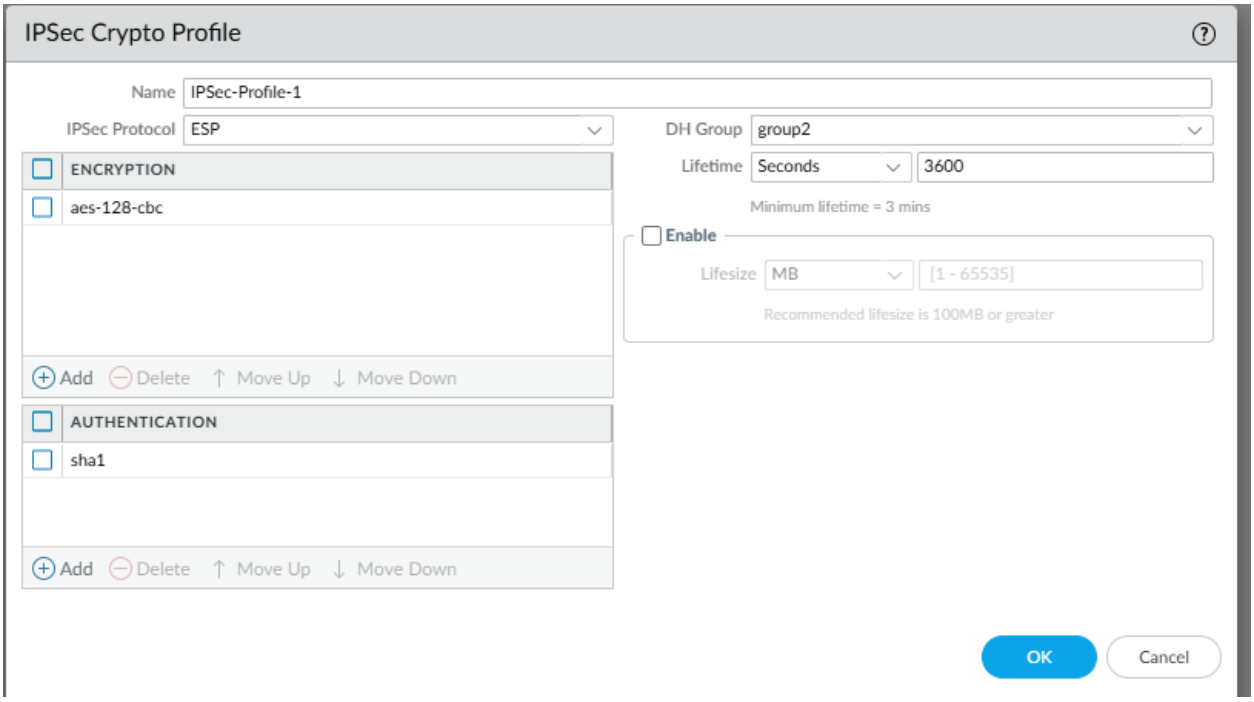


NAME	TYPE	INTERFACES / VIRTUAL SYSTEMS	ZONE PROTECTION PROFILE	PACKET BUFFER PROTECTION	LOG SETTING	User-ID			Device-ID		
						ENABLED	INCLUDED NETWORKS	EXCLUDED NETWORKS	ENABLED	INCLUDED NETWORKS	EXCLUDED NETWORKS
Inside	layer3	ethernet1/2 ethernet1/2.10 ethernet1/2.20 ethernet1/2.30	IPS_ICMP	✓		☐	any	none	☐	any	none
Outside	layer3	ethernet1/1		✓		☐	any	none	☐	any	none
vpn	layer3	tunnel.1		✓		☐	any	none	☐	any	none

Tạo IKE Crypto



Tạo Ipsec Crypto



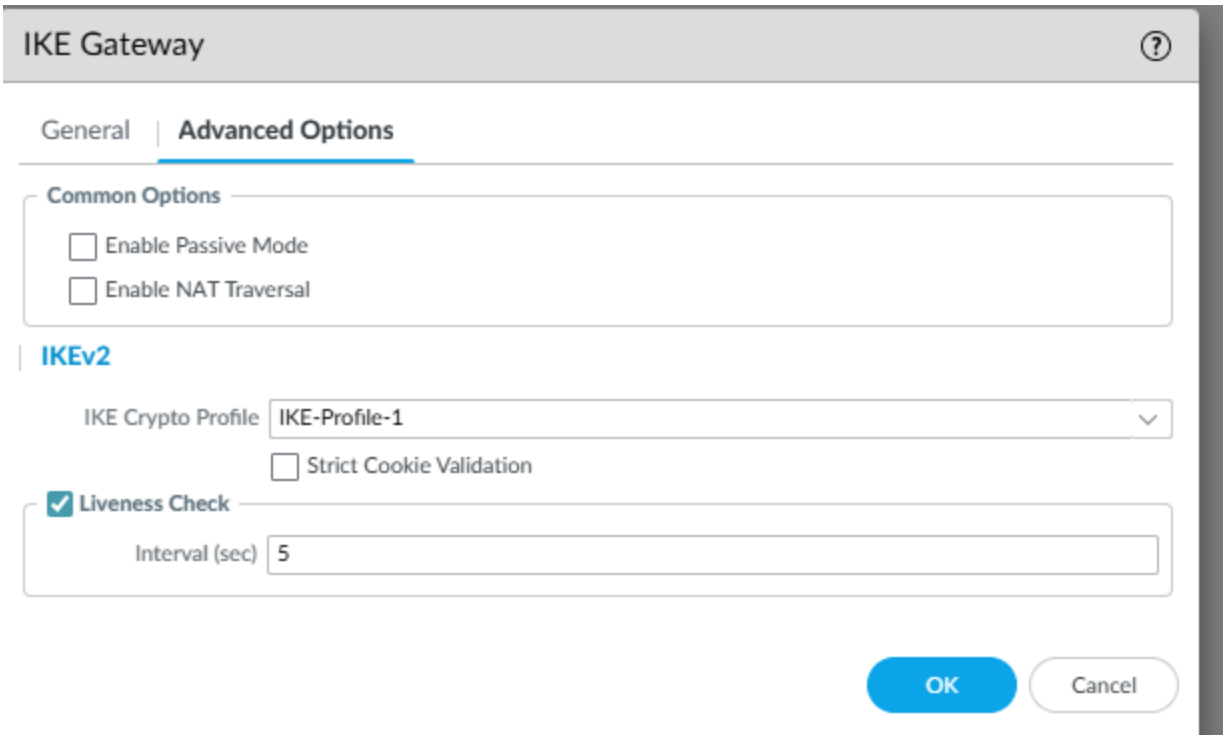
Tạo Ike Gateway:

IKE Gateway

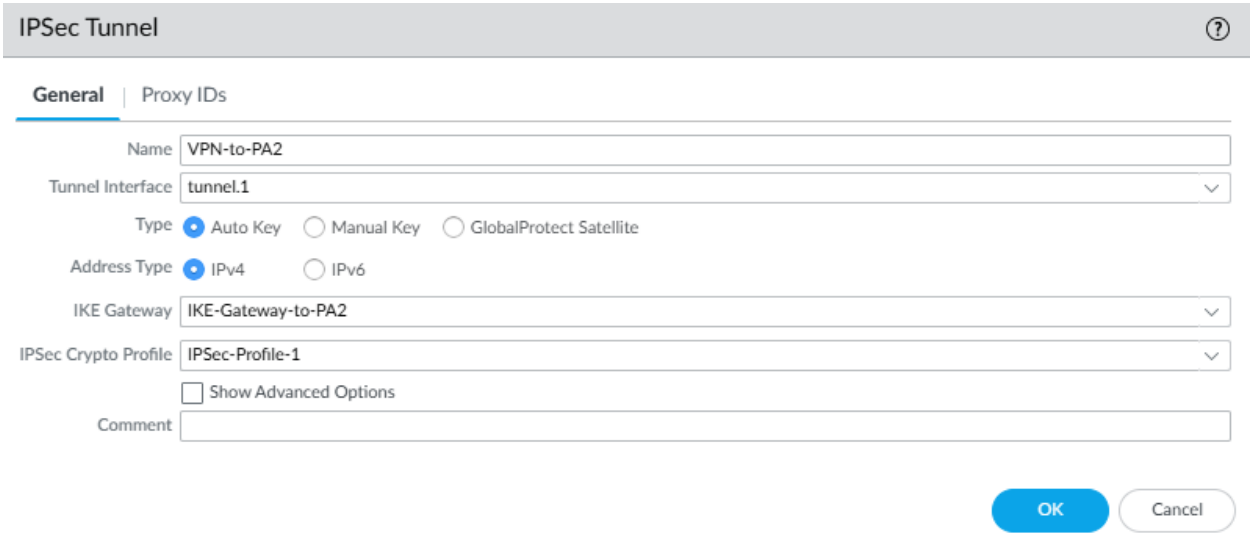
General | Advanced Options

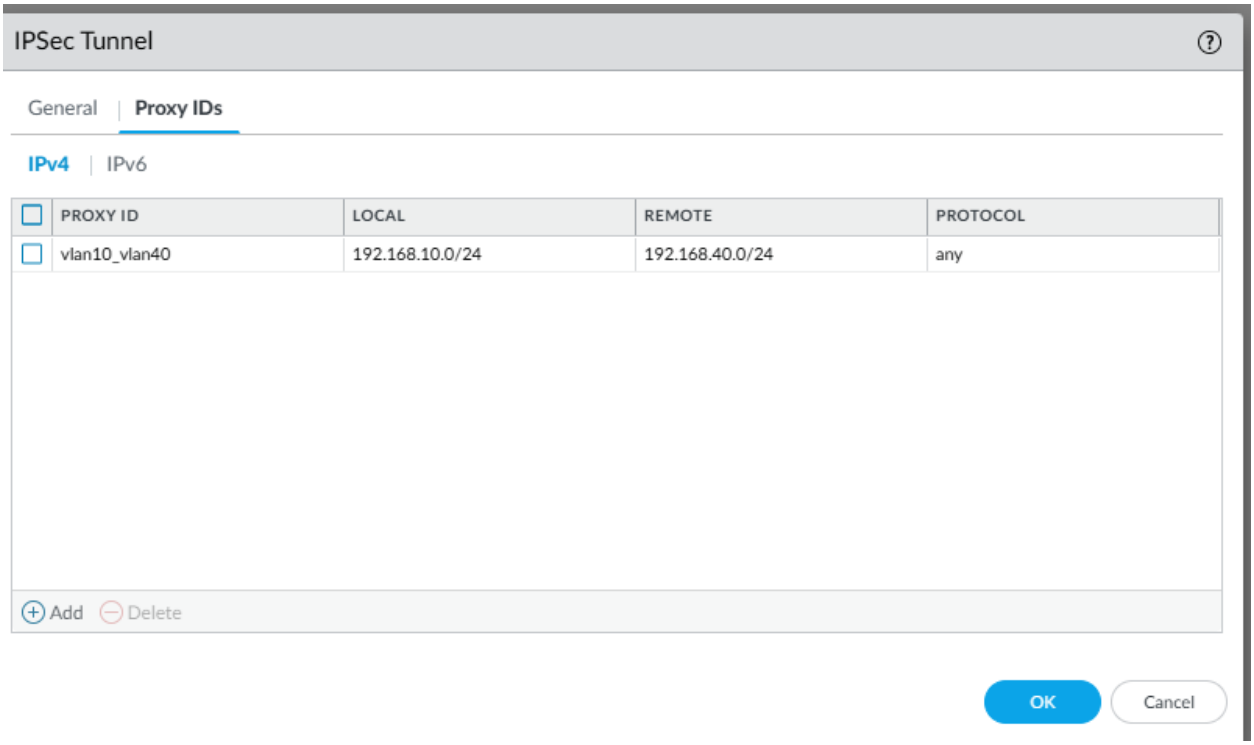
Name	IKE-Gateway-to-PA2
Version	IKEv2 only mode
Address Type	(•) IPv4 ( ) IPv6
Interface	ethernet1/1
Local IP Address	None
Peer IP Address Type	(•) IP ( ) FQDN ( ) Dynamic
Peer Address	192.168.114.50
Authentication	(•) Pre-Shared Key ( ) Certificate
Pre-shared Key	••••••••
Confirm Pre-shared Key	••••••••
Local Identification	IP address 192.168.114.100
Peer Identification	IP address 192.168.114.50
Comment	

OK Cancel



Tạo Ipsec Tunnel:





Tạo Policy security

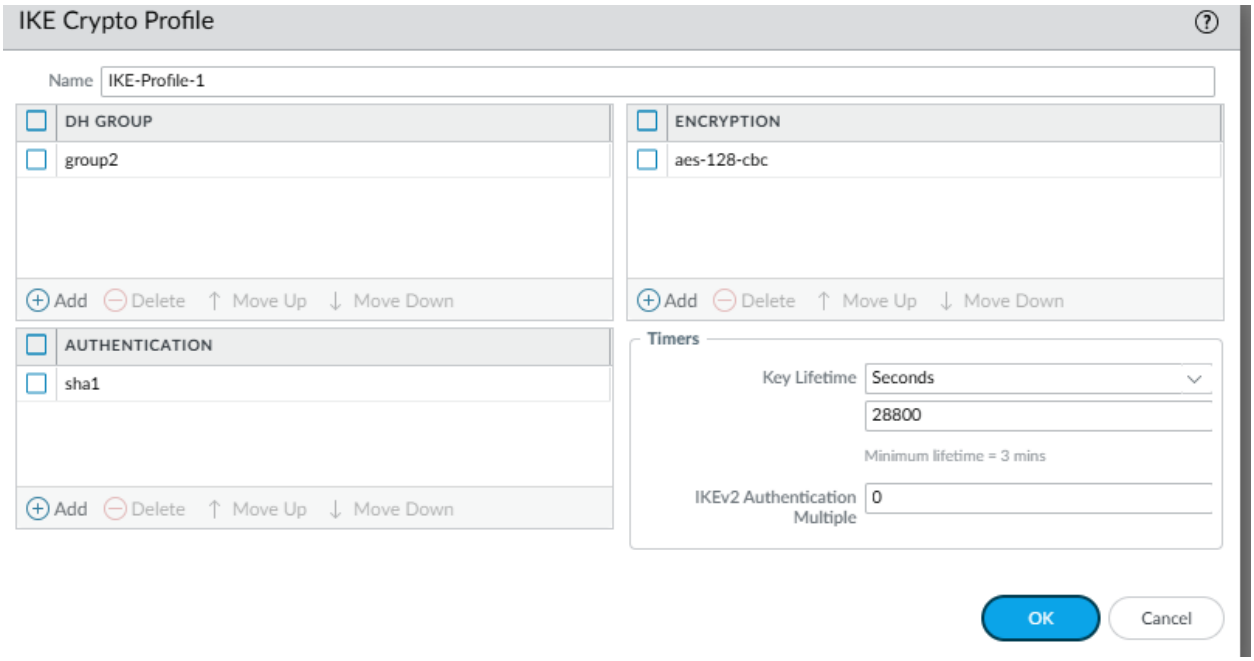
	NAME	TAGS	TYPE	Source				Destination			APPLICATION	SERVICE	ACTION	PROFILE	OPTIONS	HIT COUNT
				ZONE	ADDRESS	USER	DEVICE	ZONE	ADDRESS	DEVICE						
1	RDP_Out_in	none	universal	Outside	any	any	any	Inside	192.168.114.1...	any	ms-rdp	any	Allow	none		40
2	PA1-LAN-to-PA2-LAN	none	universal	Inside	any	any	any	vpn	any	any	any	any	Allow	none		5
3	PA2-LAN-to-PA1-LAN	none	universal	vpn	any	any	any	Inside	any	any	any	any	Allow	none		5

Trên PA2:

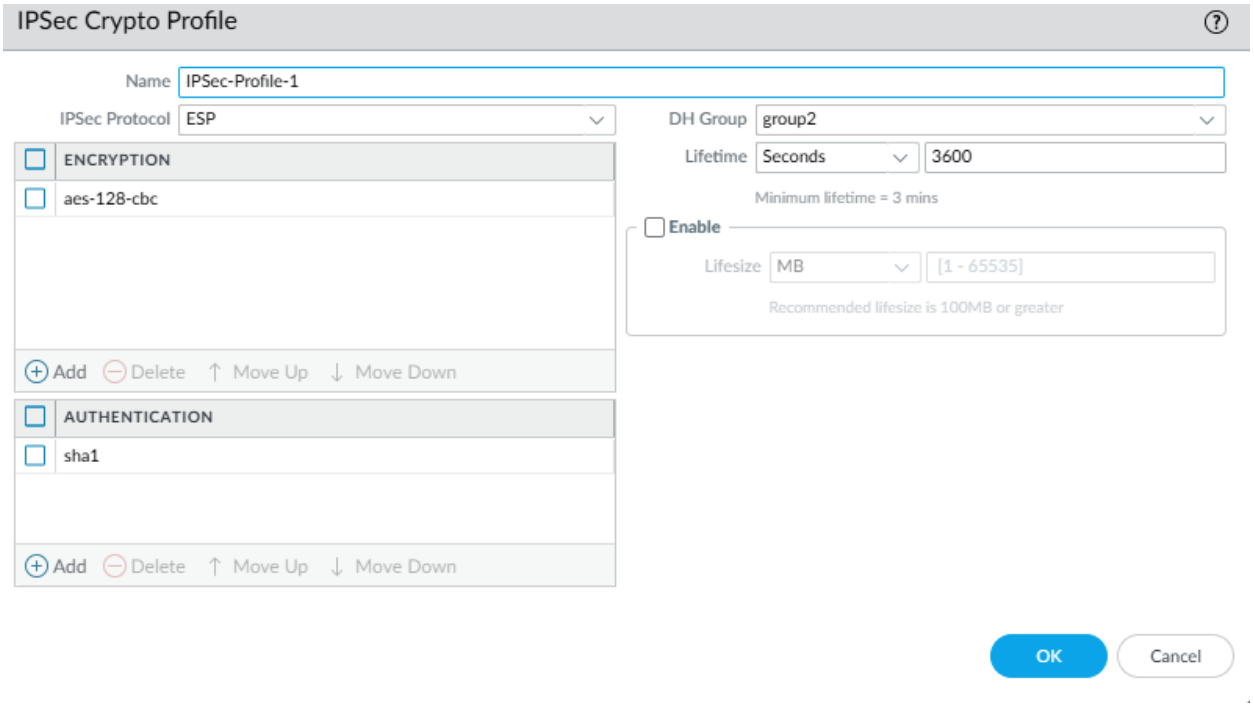
Tạo zone vpn

NAME	TYPE	INTERFACES / VIRTUAL SYSTEMS	ZONE PROTECTION PROFILE	PACKET BUFFER PROTECTION	LOG SETTING	User-ID			Device-ID		
						ENABLED	INCLUDED NETWORKS	EXCLUDED NETWORKS	ENABLED	INCLUDED NETWORKS	EXCLUDED NETWORKS
Inside	layer3	ethernet1/2 ethernet1/2.40		✓		☐	any	none	☐	any	none
Outside	layer3	ethernet1/1		✓		☐	any	none	☐	any	none
vpn	layer3	tunnel.2 tunnel		✓		☐	any	none	☐	any	none

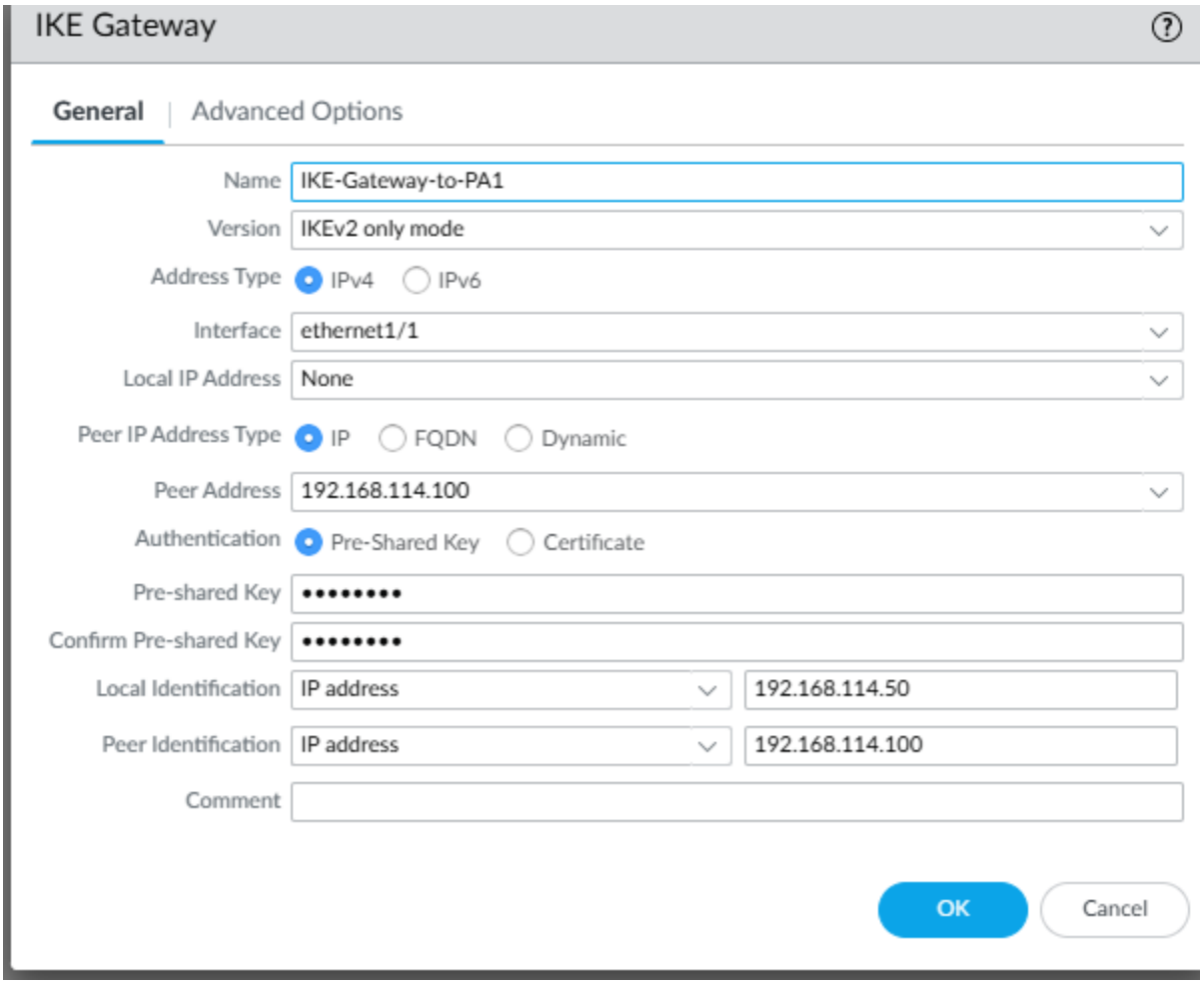
Tạo IKE Crypto



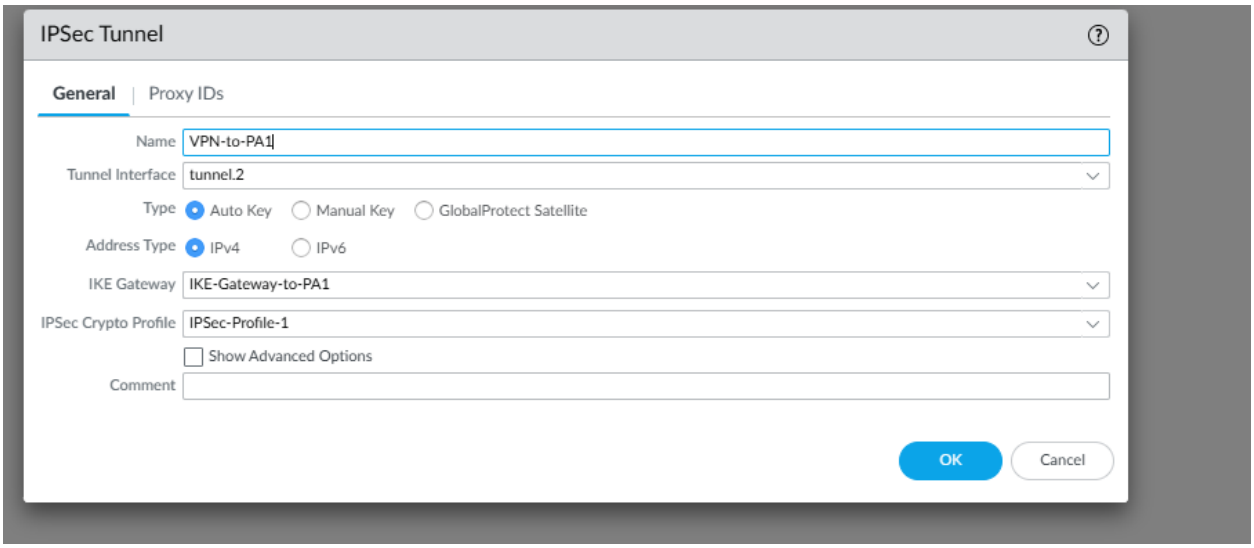
Tạo IPSec Crypto

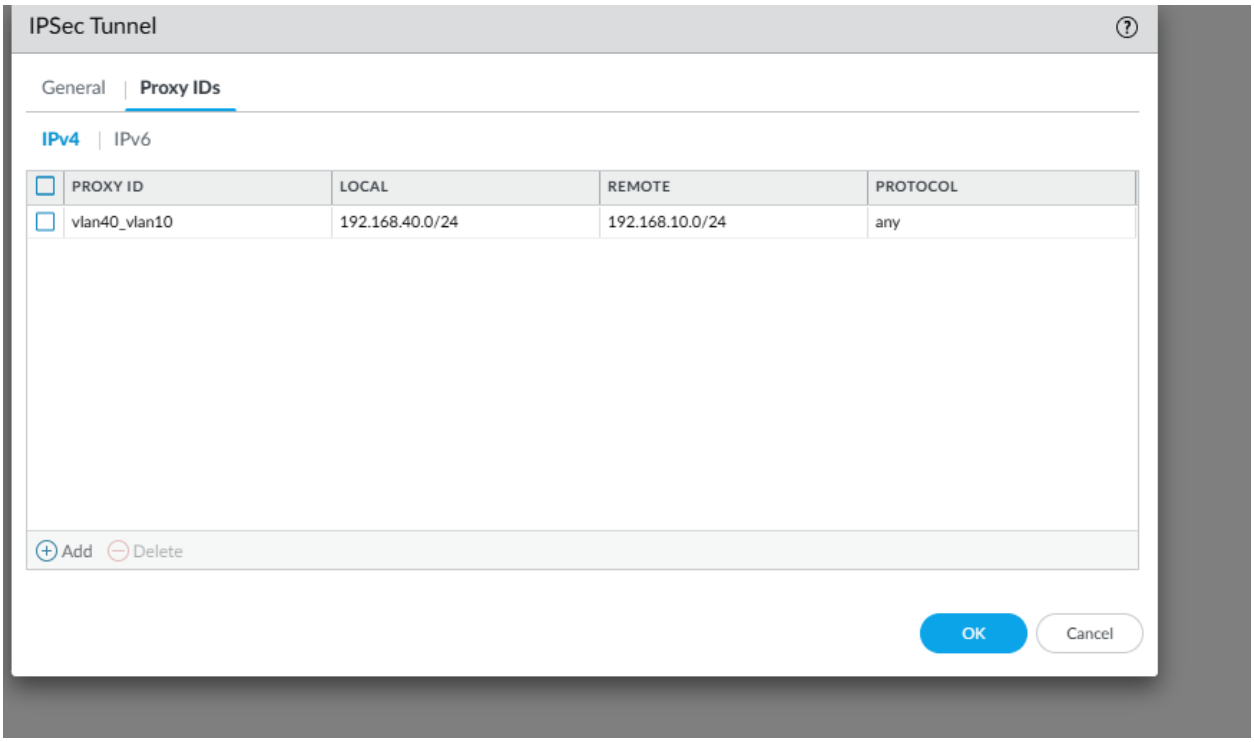


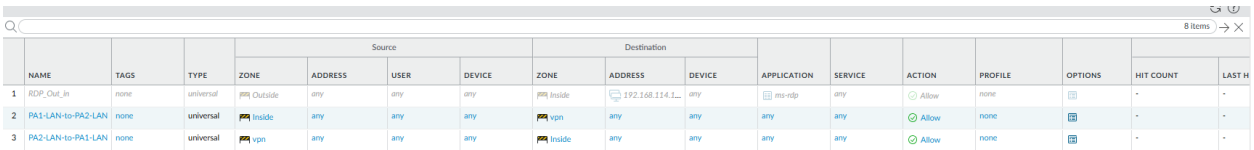
Tạo IKE Gateway



Tạo IPSec Tunnel







Kiểm tra

PC ở VLAN 10 HCM

```
PC1> show ip

NAME        : PC1[1]
IP/MASK     : 192.168.10.10/24
GATEWAY     : 192.168.10.1
DNS         : 8.8.8.8  8.8.4.4
DHCP SERVER : 192.168.10.1
DHCP LEASE  : 59993251, 60000000/30000000/52500000
MAC         : 00:50:79:66:68:00
LPORT       : 10007
RHOST:PORT  : 127.0.0.1:10008
MTU:        : 1500
```

PC ở VLAN 40 HN

```
PC4> show ip

NAME        : PC4[1]
IP/MASK     : 192.168.40.10/24
GATEWAY     : 192.168.40.1
DNS         : 8.8.8.8  8.8.4.4
DHCP SERVER : 192.168.40.1
DHCP LEASE  : 59993994, 60000000/30000000/52500000
MAC         : 00:50:79:66:68:03
LPORT       : 10013
RHOST:PORT  : 127.0.0.1:10014
MTU:        : 1500
```

Ping:

```
PC4> ping 192.168.10.10
192.168.10.10 icmp_seq=1 timeout
192.168.10.10 icmp_seq=2 timeout
84 bytes from 192.168.10.10 icmp_seq=3 ttl=62 time=5.211 ms
84 bytes from 192.168.10.10 icmp_seq=4 ttl=62 time=4.283 ms
84 bytes from 192.168.10.10 icmp_seq=5 ttl=62 time=5.495 ms

PC4> ping 192.168.10.10
84 bytes from 192.168.10.10 icmp_seq=1 ttl=62 time=4.618 ms
84 bytes from 192.168.10.10 icmp_seq=2 ttl=62 time=4.816 ms
84 bytes from 192.168.10.10 icmp_seq=3 ttl=62 time=5.241 ms
84 bytes from 192.168.10.10 icmp_seq=4 ttl=62 time=4.990 ms
84 bytes from 192.168.10.10 icmp_seq=5 ttl=62 time=4.381 ms
```

```
admin@PA-VM> show vpn ike-sa

There is no IKEv1 phase-1 SA found.

There is no IKEv1 phase-2 SA found.


IKEv2 SAs
Gateway ID      Peer-Address           Gateway Name
hm              Established     Expiration      Xt Child  ST
----------      ------------           ------------
--              -----------     ----------      -- -----  --
1               192.168.114.50         IKE-Gateway-to-PA2
2/A128/SHA1    Aug.08 15:23:33 Aug.08 23:23:33 0  2      Established

IKEv2 IPSec Child SAs
Gateway Name                                                    TnID     Tunnel
             ID       Parent   Role SPI(in)  SPI(out) MsgID    ST
------------                                                    ----     ------
-------  -------- -----    --
8B7033B2 A80945BB 00000001 Mature

Show IKEv2 SA: Total 1 gateways found. 1 ike sa found.
```

```
admin@PA-VM> show vpn ipsec-sa

GwID/client IP  TnID   Peer-Address           Tunnel(Gateway)
                                                 Algorithm          SPI(in)  SPI(out) life(Sec/KB)
ec)
--------------  ----   ------------           --------------
                                                 ---------          -------  -------- ------------
---
1               2      192.168.114.50         VPN-to-PA2:vlan10_vlan40(IKE-Gateway-to-PA2)
                                                 ESP/A128/SHA1      8B7033B2 A80945BB 3600/Unlimited


Show IPSec SA: Total 1 tunnels found. 1 ipsec sa found.
```

Chương 4:KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

4.1. Kết luận

Qua quá trình nghiên cứu, thiết kế và triển khai hệ thống tường lửa thế hệ mới cho doanh nghiệp, đề tài đã đạt được những kết quả đáng ghi nhận cả về lý thuyết lẫn thực hành. Trước hết, ở khía cạnh lý thuyết, tiểu luận đã trình bày một cách toàn diện về công nghệ tường lửa, từ các mô hình truyền thống đến tường lửa thế hệ mới (Next-Generation Firewall – NGFW), phân tích ưu – nhược điểm, các tính năng bảo mật tích hợp, cũng như xu hướng phát triển công nghệ này trong bối cảnh an ninh mạng ngày càng phức tạp. Điều này giúp xây dựng nền tảng kiến thức vững chắc để áp dụng vào thiết kế hệ thống bảo mật phù hợp với nhu cầu thực tế của doanh nghiệp.

Ở khía cạnh triển khai thực tế, hệ thống NGFW sử dụng giải pháp Palo Alto đã được cấu hình đầy đủ các tính năng quan trọng như: phân vùng bảo mật (Security Zones), định tuyến (Routing), NAT, chính sách bảo mật (Security Policy), IPS, SSL Decryption, kiểm soát tệp tin và mã độc, lọc URL, quản lý ứng dụng, VPN site-to-site, VPN remote access và cấu hình High Availability (HA) để đảm bảo tính liên tục của dịch vụ. Quá trình thử nghiệm cho thấy hệ thống hoạt động ổn định, đáp ứng tốt các yêu cầu đặt ra: bảo vệ tài nguyên nội bộ, ngăn chặn truy cập trái phép, giám sát lưu lượng, và tạo kênh kết nối an toàn cho nhân viên làm việc từ xa hoặc kết nối giữa các chi nhánh.

Ngoài ra, việc phân tích kết quả thử nghiệm cho thấy giải pháp tường lửa NGFW không chỉ đảm bảo an toàn ở mức độ mạng mà còn hỗ trợ kiểm soát sâu ở lớp ứng dụng, giúp doanh nghiệp quản lý lưu lượng một cách chi tiết và linh hoạt hơn so với các giải pháp truyền thống. Tuy nhiên, triển khai NGFW cũng đặt ra một số thách thức như yêu cầu phần cứng đủ mạnh, chi phí bản quyền cao và đòi hỏi đội ngũ vận hành có kiến thức chuyên môn tốt để cấu hình và tối ưu hệ thống.

4.2. Hướng phát triển

Trong tương lai, để nâng cao hơn nữa hiệu quả bảo mật và tối ưu hiệu suất hệ thống, giải pháp tường lửa NGFW có thể được phát triển theo các định hướng sau:

Tích hợp sâu hơn với các hệ thống bảo mật khác

NGFW nên được đồng bộ với hệ thống giám sát an ninh tập trung (SIEM) và các nền tảng phản ứng sự cố tự động (SOAR). Điều này cho phép doanh nghiệp không chỉ phát hiện mối đe dọa nhanh hơn mà còn phản ứng ngay lập tức theo kịch bản định sẵn, giảm thiểu tối đa tác động của sự cố.

Ứng dụng trí tuệ nhân tạo và học máy (AI/ML)

Việc tích hợp AI/ML vào NGFW sẽ giúp phát hiện các mối đe dọa mới (zero-day) dựa trên phân tích hành vi thay vì chỉ dựa vào chữ ký (signature). AI cũng giúp giảm cảnh báo giả và tự động tối ưu chính sách bảo mật dựa trên tình hình thực tế của mạng.

Ứng dụng trí tuệ nhân tạo và học máy (AI/ML)

Việc tích hợp AI/ML vào NGFW sẽ giúp phát hiện các mối đe dọa mới (zero-day) dựa trên phân tích hành vi thay vì chỉ dựa vào chữ ký (signature). AI cũng giúp giảm cảnh báo giả và tự động tối ưu chính sách bảo mật dựa trên tình hình thực tế của mạng.

Tăng cường bảo vệ thiết bị đầu cuối (Endpoint Protection)

Bên cạnh việc bảo vệ tại lớp mạng, cần tích hợp NGFW với các giải pháp EDR/XDR để mở rộng khả năng giám sát và bảo vệ đến từng máy trạm, máy chủ. Điều này đặc biệt quan trọng trong bối cảnh nhiều cuộc tấn công bắt nguồn từ người dùng cuối.

Mở rộng khả năng phân tích và báo cáo

Xây dựng hệ thống báo cáo trực quan, dễ hiểu và có khả năng phân tích xu hướng tấn công sẽ giúp ban lãnh đạo doanh nghiệp ra quyết định nhanh chóng và chính xác hơn trong các tình huống khẩn cấp.

Tối ưu hiệu năng và khả năng mở rộng

Doanh nghiệp nên nghiên cứu áp dụng các giải pháp cân bằng tải (Load Balancing) hoặc tường lửa phân tán để đảm bảo hiệu suất xử lý ngay cả khi lưu lượng tăng đột biến.

Đồng thời, việc lập kế hoạch mở rộng hạ tầng cần được thực hiện song song với việc cập nhật phần mềm để đáp ứng các yêu cầu bảo mật mới.

Với những hướng phát triển này, hệ thống tường lửa thế hệ mới sẽ không chỉ là một công cụ phòng thủ mà còn trở thành một phần trong chiến lược an ninh mạng chủ động, thông minh và thích ứng nhanh với sự thay đổi của môi trường đe dọa.

TÀI LIỆU THAM KHẢO

1. Cisco Systems. (2023). *Cisco Firepower Next-Generation Firewall Data Sheet*. Truy cập từ https://www.cisco.com/

2. Palo Alto Networks. (2023). *Palo Alto Networks Next-Generation Firewall Overview*. Truy cập từ https://www.paloaltonetworks.com/

3. Fortinet. (2023). *FortiGate NGFW Product Information*. Truy cập từ https://www.fortinet.com/

4. Check Point Software Technologies. (2023). *Check Point Next Generation Firewall (NGFW)*. Truy cập từ https://www.checkpoint.com/

5. Scarfone, K., & Hoffman, P. (2009). *Guidelines on Firewalls and Firewall Policy* (NIST SP 800-41 Revision 1). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-41r1

6. Gartner. (2023). *Magic Quadrant for Network Firewalls*. Gartner Research.

7. Zwicky, E. D., Cooper, S., & Chapman, D. B. (2000). *Building Internet Firewalls* (2nd ed.). O'Reilly Media.

8. Symantec Enterprise. (2023). *Next-Generation Firewall Capabilities and Best Practices*. Truy cập từ https://www.broadcom.com/